INTERNAL · PRE-LAUNCH

SASTRA DEEMED UNIVERSITY · THANJAVUR

SASTRA 3D Campus Digital Twin
Perfect Launch Blueprint

Deep technical analysis and V1 readiness report: WebGL performance, enterprise security, architecture, roadmap and pre-flight checklist.



SUBJECT BUILD
SastraMap_Enterprise.html
stamp Bmuds6ios-9kbp

PREPARED FOR
Project lead (Sakthi) and
SASTRA University management

VERSION · DATE
1.0 · 2 October 2026
Classification: Internal

DOCUMENT CONTROL

About this report

Title	SASTRA 3D Campus Digital Twin: Perfect Launch Blueprint
Document type	Technical analysis and launch-readiness whitepaper
Version	1.0 (initial issue)
Date	2 October 2026
Subject	`SastraMap_Enterprise.html`, 1,357,907 bytes, build stamp `Bmuds6ios-9kbp`
Repository	`sakthizzportraits-spec/Sakthi-mapz`
Prepared by	Claude (Anthropic), AI-assisted technical review, at the request of the project lead
Audience	Project lead and engineering; SASTRA web office and IT security; university management (Section 1)
Classification	Internal. Contains security findings; do not publish before the P0 items are closed.

How to read this report

- **Management:** Section 1 (Executive Summary) is self-contained, covering verdict, priorities and value proposition.
- **Engineering:** Sections 2–4 hold the evidence, findings (PERF-xx, SEC-xx) and recommended designs. Section 6 is the launch gate.
- **Severity scale:** ▲ P0 launch blocker · ◆ P1 launch-critical · ● P2 should fix in V1.x · ▽ P3 improvement · ✔ GOOD strength to preserve. Severity is always shown with a symbol and a label, never by colour alone.
- **Evidence:** module identifiers (`c02`, `MT:1`, `NG:3` …) refer to the chunk and build tags inside the artifact; Appendix B maps them to responsibilities.

Key measurements in one table

Measure	Value	Measure	Value
Meshes · visible · shadow casters	6,271 · 5,982 · 4,999	Unique materials · geometries	1,330 · 3,191
Main-pass draws (desktop · mobile)	2,122 · 789	Shadow-refresh frame draws (desktop)	5,113
Shader programs	68–70	Instanced meshes · instances	67 · 43,374
JS heap after GC	41–42 MB	Frames while idle (20 s)	0
HTML size · with Brotli	1.36 MB · 944 KB	Same JS, plain Brotli	637 KB
URL parameters accepted	69	Global APIs exposed	16
IoT reconnects to placeholder host	every 32–60 s	404s per load	1–3

CONTENTS

Table of contents

1 Executive Summary 4

1.1 Current state at a glance 4

1.2 What must happen before launch 5

1.3 Business and brand value for SASTRA University 5

1.4 Scope and method 6

2 WebGL Performance & Efficiency Analysis 7

2.1 Measured baseline 7

2.2 Zero-allocation rendering: the requestAnimationFrame loop 8

2.3 Draw-call optimisation 10

2.4 Performance findings 12

2.5 Mobile thermal efficiency: strict coding guidelines 13

2.6 Device tiers and performance budgets 14

3 Enterprise-Grade Cybersecurity: The “Bulletproof” Layer 15

3.1 Threat model 15

3.2 Evaluation of the existing security controls 16

3.3 Prioritised security findings 17

3.4 URL parameter attack-surface analysis 20

3.5 Recommended HTTP security headers 21

3.6 WebSocket and IoT data-validation strategy 22

4 Code Architecture & Scalability 25

4.1 The architecture as built 25

4.2 Target architecture: state, DOM and modularity 27

4.3 Blueprint: from static campusData to an API-driven platform 28

4.4 A* pathfinding readiness and NavMesh strategy 30

4.5 Bundle architecture for scale 31

4.6 Engine currency: three.js r128 31

5 Future-Proof Feature Roadmap 32

5.1 Phase 1: The Perfect V1 Launch (weeks 0–8) 32

5.2 Phase 2: The Smart Campus (months 3–9) 34

5.3 Phase 3: Next-Gen experiences (months 9–18) 34

6 The “Perfect Launch” Pre-Flight Checklist 36

6.1 Build and bundle 36

6.2 CDN caching and compression 36

6.3 Asset optimisation 37

6.4 Security and privacy configuration 37

6.5 Fallback states for unsupported or degraded environments 38

6.6 Accessibility, SEO and sharing 38

6.7 Observability and launch runbook 38

6.8 Sign-off 39

Reference Inventories & Method **40**

A URL parameter inventory (69 parameters) 40

B Module inventory 41

C Browser storage inventory 42

D Global API surface (measured at runtime) 43

E Methodology, environment and limitations 43

SECTION 1

Executive Summary

The SASTRA 3D Campus Digital Twin is an unusually ambitious, carefully engineered web application. In a single 1.36 MB file it delivers a procedurally built 3D campus, bilingual (English/Tamil) building and room directories, search, worker-based A* routing, GPS positioning, a wake-word voice assistant, cinematic tours, WebXR AR, an emergency-evacuation mode and an IoT digital-twin layer. Its frame scheduler and defensive coding are of professional quality. **It is not yet ready for a public V1 launch**: a small number of concentrated issues in safety-relevant URL handling, mobile GPU load, deployment configuration and code governance must be closed first. None of them requires redesigning the product. With focused effort the launch is achievable in about eight weeks.

VERDICT: CONDITIONAL GO

Proceed to a public V1 once the eight ▲ P0 items in Table 1-2 are closed and verified against the §6 checklist. Everything else in this report can follow in V1.x without blocking launch.

Launch-readiness scorecard

Scores out of 10, assessed against what a public, university-branded web application needs at launch. Each bar shows status by colour *and* a label.

Product vision & feature depth	9/10	✓ STRONG
Frame scheduling & idle efficiency	9/10	✓ STRONG
GPU load: draws, shadows, materials	3/10	◆ WEAK
Mobile thermal readiness	4/10	◆ WEAK
Security posture	4/10	◆ WEAK
Privacy & compliance readiness	5/10	● FAIR
Architecture & maintainability	4/10	◆ WEAK
Data / API readiness	3/10	◆ WEAK
Routing & navigation readiness	7/10	✓ STRONG
Accessibility	6/10	● FAIR
Deployment & operations readiness	3/10	◆ WEAK
Overall launch readiness	5.2/10	◆ CONDITIONAL

1.1 Current state at a glance

DELIVERED ARTIFACT
1.36 MB
single HTML · 944 KB with Brotli

APPLICATION CODE
47
modules · ≈ 2.3 MB minified JS + three.js r128

BUILD GENERATIONS
7
Optimized V1 → … → Enterprise

CAMPUS CONTENT
257
room entries · 16 academic blocks · 41 placed buildings

MAIN-PASS DRAW CALLS	SHADOW-REFRESH FRAME	IDLE FRAMES (20 S)	JS HEAP AFTER GC
2,122	**5,113**	**0**	**42 MB**
desktop · 789 on low-tier phone	draw calls (desktop) · budget 1,500	loop parks perfectly when idle	healthy on every profile

1.2 What must happen before launch

Table 1-2 · Priority actions (P0 = launch blocker, P1 = launch-critical, risk-acceptable only by sponsor)

Priority	Ref	Action	Effort
▲ P0	SEC-01	Remove the URL-triggered evacuation banner (`?evac=1`) and the global emergency toggle. Emergency state must come only from a signed, authenticated source.	< 1 day
▲ P0	SEC-02	Fix the domain lock: it would blank the page on a `sastra.edu` domain, yet accepts any `*.vercel.app` clone.	< 1 day
▲ P0	SEC-05 / PERF-06	Ship with the IoT twin off and no placeholder endpoint. Today every visitor retries `wss://sastra-iot-telemetry.local` every 30–60 s.	< 1 day
▲ P0	SEC-07	Production allowlist for URL parameters (69 are accepted today); clamp numeric values.	2–3 days
▲ P0	PERF-01	Enable the adaptive resolution governor and tier policy by default. The “quality lock” currently pins phones at DPR 2.	1–2 days
▲ P0	PERF-02	Cut shadow cost: caster culling, a single shadow light below the high tier, refresh only on change.	3–5 days
▲ P0	SEC-03	Deliver HTTP security headers (CSP, HSTS, Permissions-Policy, frame-ancestors) from the CDN. There is no CSP today.	2–3 days
▲ P0	B-1	Put authoring sources, build scripts and a reproducible build in Git. The repository holds only built HTML.	1–2 days
◆ P1	PERF-03/04	Low tier: no logarithmic depth, no MSAA render target, default GPU power preference.	1 day
◆ P1	SEC-04/06	Remove the `?geo=` origin override and the 16 global control APIs from public builds.	1–2 days
◆ P1	SEC-10/11	Remove anti-copy and paste blocking. Push-to-talk voice with a privacy notice (DPDP Act 2023).	2 days
◆ P1	ROUTE	One A* engine with an accessible-routing profile; directions from “My location” or Main Gate.	1–2 weeks

1.3 Business and brand value for SASTRA University

ADMISSIONS AND REPUTATION

- **A campus visit before the visit.** Prospective students and parents, including those in other states and abroad, can explore every school, lab block and hostel from a phone. That is the most persuasive admissions asset a residential university can own.

OPERATIONS AND CAMPUS LIFE

- **Wayfinding at scale:** freshers’ week, Kuruksastra and Daksh fests, convocation, conferences, and accreditation peer-team visits, with fewer staff hours spent giving directions.
- **Room-level search:** “TDC 207” or “Moot Court” resolves to building, floor and route.

- **A showcase of SASTRA engineering.** A student-built digital twin with worker-threaded routing, WebXR and IoT readiness signals the institution's technical culture far better than a brochure.
- **Content engine.** Grand Tour flights and future drone tours become reels and videos for admissions campaigns.
- **Bilingual identity.** Tamil names and descriptions throughout reflect the university's roots and serve Tamil-medium families.
- **Safety and resilience platform:** once governed (SEC-01), the evacuation and closure layers become a real communication channel for Campus Security.
- **Smart-campus and sustainability evidence:** live energy, occupancy and parking views support facilities planning and accreditation narratives on infrastructure and green campus.
- **Low running cost:** static CDN hosting, no app-store dependency, offline-capable as a PWA.

Table 1-3 · Suggested success metrics for management reporting (privacy-safe, aggregate only)

Objective	KPI	V1 target (first 6 months)
Admissions reach	Sessions from admissions campaigns; tour completions	≥ 25k sessions; ≥ 30% tour completion
Wayfinding utility	Search success rate (result opened); routes requested	≥ 85% success; ≥ 10k routes
Event readiness	Peak concurrent users served with no errors on fest and convocation days	≥ 5k concurrent; error rate < 0.5%
Inclusion	Tamil-language sessions; accessible-route usage	Tracked from launch
Quality	Crash-free sessions; p95 frame time on low tier	≥ 99.5%; ≤ 33 ms

1.4 Scope and method

The analysed artifact is `SastraMap_Enterprise.html` (1,357,907 bytes, SHA-256 `316760ee…4019`, build stamp `Bmuds6ios-9kbp`). Its packed payload was decoded byte-for-byte using the build's own algorithm (7-bit unpacking and raw DEFLATE), split into its 27 chunks, and pretty-printed for review alongside the 21 inline shell scripts and both style sheets. In total about 112,000 formatted lines were covered, and three.js r128 was treated as a vendor library. Findings are referenced to module and function names so they can be traced. Runtime behaviour was measured by loading the unmodified file in headless Chromium with WebGL and three.js instrumentation, in a desktop profile and a mobile low-tier profile (Appendix E). In line with the brief, **no code was changed**: this report documents and recommends.

SECTION 2

WebGL Performance & Efficiency Analysis

Frame *scheduling* in this build is exemplary. Frame *content* is the problem. The render loop parks completely when nothing changes, allocates almost nothing per frame, and throttles itself through idle tiers. But each frame it does draw contains about 6,000 meshes, 1,330 materials and about 5,000 shadow casters. Draw calls and shadow passes, not JavaScript, are the binding constraint on phones.

2.1 Measured baseline

All figures were captured by instrumenting the unmodified build in headless Chromium (Playwright 1.56, ANGLE/SwiftShader). Every WebGL draw call was intercepted, and the three.js renderer was wrapped to attribute calls to passes. Counts (draws, triangles, objects, materials, programs) are independent of the GPU and are exact. Timings under a software rasteriser are pessimistic and are reported only where they indicate relative cost.

MESHES IN SCENE
6,271
5,982 visible · 891 groups · 7,208 objects

UNIQUE MATERIALS
1,330
1,047 Standard · 85 Physical · 77 Lambert

SHADOW CASTERS
4,999
visible meshes with `castShadow`

SHADER PROGRAMS
68–70
compiled at boot (desktop / mobile)

Table 2-1 · Per-frame render cost by platform profile

Metric	Desktop · 1440×900 · DPR 1	Mobile · Pixel 7 emulation · 4 GB	Note
Device tier selected by the build	high	low (≤ 4 GB)	From `SW.Q`
Effective pixel ratio · main render target	1.0 · 1440×900	**2.0** · 824×1678	Quality lock pins min(DPR, 2)
Main-pass draw calls	2,122	789	Distance/LOD culling active
Main-pass triangles	3.34 M	1.35 M	
Shadow-refresh draw calls (extra)	≈ 2,180–2,990	≈ 3,076	Every shadow update
Total triangles in a shadow-refresh frame	11.3–13.3 M	3.7 M	Shadow passes > 2× main
Shadow-casting lights · map size	1 dir + 3 spot · 4096²/1024²	1 dir · 512²	2048² under software GL
Post-processing passes	MSAA RT + 4 quarter-res	MSAA RT + 4 quarter-res	Bright, blur ×2, composite
Instanced meshes · instances	67 · 43,374	67 · 25,614	Crowds and props reduced on low tier
Visible vertices (incl. instances)	12.56 M	8.41 M	3.83 M unique
GPU textures · geometries (three.js)	269 · 2,003	93 · 1,800	Texture cap 512 px on low tier

Metric	Desktop · 1440×900 · DPR 1	Mobile · Pixel 7 emulation · 4 GB	Note
Logarithmic depth buffer	on	on	Disables early-Z
JS heap after GC	42.0 MB	41.3 MB	Healthy
Frames rendered in 20 s without input	**0**	**5**	Loop parking works
GL buffers created at boot · deleted	10,107 · 598	n/m	Geometry fragmentation

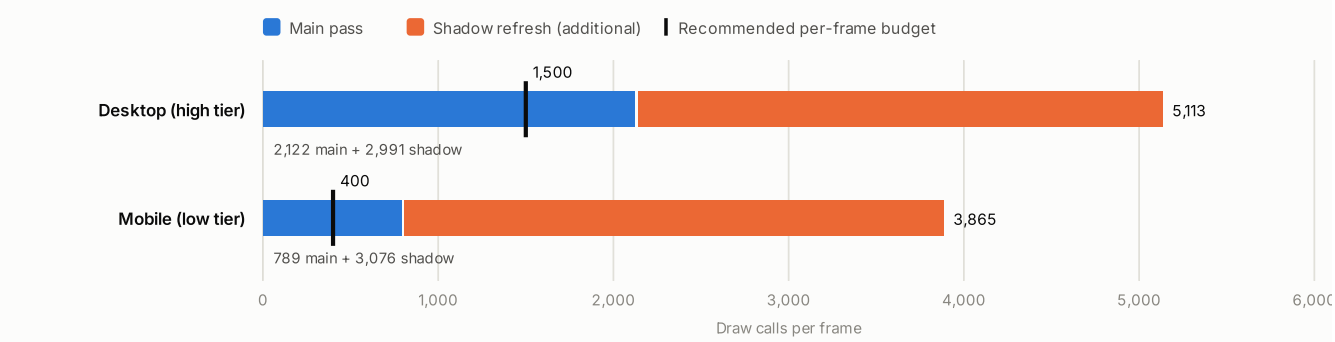


Figure 2-1. Draw calls in a frame that refreshes shadows, measured on the warm-up frame of each profile. Desktop steady-state refresh frames measured 4,301 calls. Both profiles exceed the recommended budget roughly 3× (desktop) and 10× (mobile).

2.2 Zero-allocation rendering: the `requestAnimationFrame` loop

What the loop does right

The main loop (`ii()` in the core module) is engineered with real care for garbage collection and power use:

- **Parking.** After 300 ms without input, once the camera has settled (`ws()`) and nothing is "engaged" (walk mode, tours, open cards), `Xa()` cancels the rAF and polls every 200 ms with `setTimeout`. **Measured: 0 frames in 20 s idle on desktop.** This is the single most important battery feature in the product.
- **Idle tiers.** When awake but idle it renders at 30/20/10 fps on desktop and 24/12/6 fps on touch devices, stepping down at 4–8 s and 12–20 s.
- **Guards.** It returns early when the tab is hidden, the context is lost, the page is unloading, or a capture is busy. Δt is clamped to 0.34 s and sub-stepped at 0.1 s, so there is no spiral of death after backgrounding.
- **Scratch objects.** The camera damping, leader-line projection (`Cc()`) and compass reuse pre-allocated vectors. DOM writes are change-detected: the compass needle is quantised to 0.1° and the FPS label is rebuilt only when its text changes.
- **Matrix freezing.** After a probe window, static objects stop recomputing their matrices; `updateMatrixWorld` is patched to skip clean subtrees.
- **Shadow scheduling.** `shadowMap.autoUpdate = false` with explicit `needsUpdate`. There is a static-shadow mode (`L0()`) that freezes casters until an instanced mesh's matrices change three times.
- **Frame-time governor.** A hysteresis-based resolution governor (miss-rate windows of 2 s, step down after 8 s, step up after 60 s, at most 3 step-ups, bounce protection) with a 256-bucket frame-time histogram. It is well designed, but switched off by default (PERF-01).

A static pass over the 31 functions called directly from the loop found allocation-free bodies in 27 of them. The other four allocate only on state change or in one-off windows: `Rc()` creates a `Float64Array` when selection changes, `Cc()` builds transform strings only when the leader line moves, `qd()` creates promises only while an async capture is pending, and `Rd()` allocates only during the matrix-freeze probe.

Measured allocation during interaction

Heap sampling (CDP `HeapProfiler`, 32 KB sampling interval) ran across a scripted interaction of four orbit drags and four zoom steps on the desktop profile. It captured **104 rendered frames and 3.79 MB of sampled allocation**, an average of about 36 KB per frame. What matters is where the bytes came from. **The render loop itself (`ii`) accounted for only about 33 KB across all 104 frames, roughly 0.3 KB per frame**, which confirms the static analysis. Nearly half of all sampled bytes (≈ 1.75 MB) came from three.js *first-use* work: cloning uniforms for newly compiled materials, creating vertex-array binding states the first time a geometry/program pair is drawn, constructing new `Object3D`s, and registering their dispose listeners. In other words, content was being created or drawn for the first time as the camera moved. Retained heap after forced GC rose from 42.9 MB to 45.9 MB. These are not steady-state leaks. They are bursts concentrated in the first minutes of a session, exactly when a visitor forms an impression. On mid-range phones a 2–5 MB burst triggers young-generation GCs of several milliseconds each during camera motion.

Table 2-1b · Sampled allocation during interaction, by origin

Allocation site	What allocates	KB	Class
`cloneUniforms` (three.js)	Uniform objects cloned when a material is compiled or cloned for the first time	452	First-use
`WebGLBindingStates` (three.js, patched `zaH3` / `zaH5`)	Vertex-array binding state created on the first draw of each geometry/program pair	866	First-use
`Object3D` constructor (three.js)	Scene objects constructed during interaction (labels, pins, LOD or detail swaps)	256	Runtime creation
`EventDispatcher.addEventListener`	Dispose listeners for newly created geometries and materials	96	Runtime creation
`id()` (c02, matrix freeze)	Index map of 7,208 objects built when the freeze system armed mid-interaction	96	One-off
`WebGLTextures.get` / cube maps	Texture-state records on first use	77	First-use
`intersectObject` recursion (three.js)	Hover and pick raycasts; arrays allocated per pointer move	64	Per input event
Built-ins (`Map.set`, `Array.join`, `Float64Array`, `String.replace` …)	Bookkeeping in feature modules	≈ 446	Mixed
Feature modules (sphere repair, weather, hostel, acoustics, LOD rig, Campus OS, radar)	1–2 samples each (≤ 65 KB)	≈ 320	Low
`ii()` render loop	Steady-state per-frame work	33	≈ 0.3 KB/frame

ZERO-ALLOCATION RECOMMENDATIONS

- **Pre-warm everything that is first-used on interaction.** After the warm-up frame, render once with all LOD levels and detail sets visible (off-screen or at 1×1 viewport) so that every program, uniform set and binding state exists before the user touches the screen. `renderer.compile()` covers programs but not binding states.
- **Pool interaction objects.** Hover rings, pins, labels and highlight meshes are created once and toggled with `visible`; never `new Object3D` in an input handler.
- **Raycast against proxies with a reused target array.** Pass a pre-allocated result array to `intersectObjects`, test merged low-poly proxies (or a BVH such as three-mesh-bvh), and coalesce pointer moves to one raycast per frame.
- **Arm the matrix freeze at boot** (PERF-05), so its 7,208-entry index is built during loading, not mid-gesture.
- **Guard it in CI.** Re-run this sampling harness on every release and fail the build if loop-attributed allocation exceeds 1 KB per frame or the post-interaction retained heap grows by more than 5 MB.

Remaining GC and CPU risks

- **Per-frame hook chains.** `SW.H` is re-wrapped by 23 layers and `SW.rk` by 4, so every frame walks a closure chain whose length depends on build order. It is cheap per call but opaque, and one throwing layer silently disables the rest (empty catches).
- **Late matrix freeze.** A probe-then-freeze system (`Rd()` / `cd()`, plus a patched `Object3D.updateMatrixWorld`) sets `matrixAutoUpdate = false` on everything that has not moved, but only after **90 rendered frames and 2.6 s** of probing. Because the loop parks when idle, a visitor who opens the map and looks around briefly may never reach 90 frames. At census time 6,609 of 7,208 objects were still auto-updating, which costs about 7,000 matrix compositions per rendered frame. Freeze static content at build or boot time instead, and probe only the known-dynamic subtrees.
- **Boot churn.** 10,107 GL buffers and 325 textures created during boot (≈ 229 MB of texture uploads counted at `texImage2D`, including canvas re-uploads), plus 48 long tasks (worst 2.9 s under software GL). Most of this is procedural generation that could be baked at build time.
- **Global `Math.random` swapping** (60 sites) during generation: correct today, but any async callback that runs between a swap and its restore receives seeded values.

2.3 Draw-call optimisation

The scene is procedurally constructed: buildings are assembled from `BoxGeometry` (236 construction sites in code), `ExtrudeGeometry` (28) and canvas textures, with one mesh per architectural part. Instancing is already used (67 instanced meshes, 25–43k instances), and a post-load geometry de-duplication pass (`ddPool`) shares identical buffers. Without **material unification**, though, geometry cannot be merged: 1,330 distinct materials mean at least one draw call per material per visible cell, and in practice one per mesh.

Table 2-2 · Draw-call reduction plan (in order of payoff)

#	Technique	Application to this codebase	Expected effect
1	**Material registry and dedupe**	Key every material by its parameters (type, colour, roughness, metalness, maps, flags). Replace per-mesh `new MeshStandardMaterial` (155 construction sites) with registry lookups. Move per-building tint into vertex colours or an instance attribute. Retire `MeshPhysicalMaterial` (85) on the low tier.	1,330 → < 60 materials; programs 68 → < 30
2	**Static geometry merging**	After materials are unified, merge static meshes per material per spatial cell (e.g. a 100 m grid) with `BufferGeometryUtils.mergeGeometries` at build time, keeping a per-part id attribute for picking and highlighting (GPU picking or an id texture instead of per-mesh raycasts).	Main pass 2,122 → 300–500
3	**Instancing for repeats**	Extend the existing `InstancedMesh` usage to every repeated prop: windows, columns, railings, lamps, benches, bollards, trees and vehicles. Use per-instance colour for variation.	−20–40% of remaining
4	**Texture atlasing and array textures**	Canvas-generated façade tiles are packed into atlases or `DataArrayTexture` layers so different façades share one material (layer index per instance or vertex).	Enables #2 for façades
5	**Shadow-caster culling**	Only meshes whose bounding-sphere radius exceeds ~2 m (or an explicit flag on hero buildings) cast shadows. Props, trims and windows don't. Use a separate low-poly proxy merged into one caster mesh per cell.	Shadow draws −80–90%
6	**Baked lighting for statics**	Bake sun shadow and ambient occlusion for buildings and ground into lightmaps or vertex AO at build time. Keep one dynamic shadow map only for moving actors.	Shadow refresh draws → < 100
7	**BatchedMesh** (three.js r159+)	After the engine upgrade, draw thousands of different static parts in one call with per-object visibility and culling, which keeps picking simple without merging.	Alternative to #2
8	**Hierarchical culling**	The existing screen-size culling (`ddK2`) and LOD module (`SastraLOD` , 420 m reach) are kept. Add cell-level frustum culling so 6,000 per-mesh frustum tests become about 100 cell tests.	CPU −2–4 ms/frame

2.4 Performance findings

PERF-01 The default “quality lock” disables the adaptive resolution governor and Eco persistence

▲ P0 · MOBILE BLOCKER

EVIDENCE `_N6.W` is `true` unless the URL has `?lock=0`. When true, `ms = 2`, so `Ta()` returns `min(devicePixelRatio, 2)` and bypasses the governor ladder. Separately, the “gov” performance governor (c22) is disabled, and a persisted Eco Mode preference is not restored (c26). Measured: the low-tier phone profile renders at DPR 2.0 (824×1678) with MSAA, log-depth and PCF-soft shadows.

FIX Invert the default: governor on, starting from a tier-specific ceiling (low 1.25, mid 1.5, high 2.0). Restore Eco persistence. Keep the lock only as a capture or marketing mode (`?lock=1` on localhost).

PERF-02 Shadow passes cost more than the main pass

▲ P0

EVIDENCE 4,999 visible shadow casters. A shadow-refresh frame adds about 2,200–3,100 draw calls and 2–3× the main pass’s triangles. On desktop, 1 directional (4096^2) plus 3 spot lights (1024^2) cast shadows. On the low tier, the directional map shrinks to 512^2 but still redraws every caster. Refresh runs every frame at idle tiers and every other frame during interaction, unless static-shadow mode is armed.

FIX Apply techniques 5 and 6 from Table 2-2. Refresh shadows only on sun movement or dynamic-caster change. Use one 1024^2 map on mobile and drop spot-light shadows below the high tier.

PERF-03 Logarithmic depth buffer is on for every tier

◆ P1

EVIDENCE `logarithmicDepthBuffer: true` unless `?logz=0`. three.js then writes `gl_FragDepth` in every fragment shader, which disables early-Z and hidden-surface removal on tile-based mobile GPUs (Mali, Adreno, Apple). With MSAA and heavy overdraw (trees, façades) this is a direct fill-rate and power cost.

FIX Turn it off on low and mid tiers. Instead, set the camera’s near plane adaptively (≈ 0.5–1% of orbit distance) with the existing `far` of 6,000. That gives a near/far ratio under 10^4, which 24-bit depth handles comfortably at campus scale.

PERF-04 Full-resolution MSAA render target and `high-performance` GPU preference on all tiers

◆ P1

EVIDENCE The default framebuffer is created with `antialias: true`, and the scene is rendered into a multisampled target before post-processing. `powerPreference: "high-performance"` forces the discrete GPU on dual-GPU laptops.

FIX Low tier: no MSAA; FXAA or SMAA in the composite pass (cheap at DPR ≥ 1.5); `powerPreference: "default"` (or `"low-power"` in Eco). Keep MSAA ×4 on the high tier only.

PERF-05 The matrix-freeze optimisation arms too late — P2

EVIDENCE The freeze system needs 90 rendered frames before it arms. Measured 12 s after load with an idle (parked) loop, 6,609 of 7,208 objects still had `matrixAutoUpdate = true`.

FIX Mark static content frozen when it is built (it is procedurally generated, so it is known to be static), probe only animated subtrees (people, vehicles, water, tours), and arm the rest immediately after the warm-up frame. Combined with merging, the scene graph shrinks from 7,208 nodes to a few hundred.

PERF-06 Background network and timers while parked — P2

EVIDENCE The IoT bridge retried the placeholder endpoint every 32–60 s for the whole session, measured as 20 consecutive attempts while the render loop was idle. There are 19 `setInterval` sites across modules.

FIX IoT off by default (SEC-05). Pause all intervals when the loop parks (central scheduler), and use `requestIdleCallback` for housekeeping.

PERF-07 Boot work that belongs in the build — P2

EVIDENCE Time to first frame 11.2 s and ready 27–39 s under software GL, dominated by procedural generation and shader compilation (the warm-up render alone took 10 s). Real GPUs are much faster, but the work scales the same way on low-end phones.

FIX Bake geometry and textures (§6.3), reduce program count through material unification, and keep `KHR_parallel_shader_compile` and warm-up, which are already used well.

2.5 Mobile thermal efficiency: strict coding guidelines

Thermal throttling is cumulative: a phone that renders 60 fps at full DPR for five minutes will drop to half clock and then stutter. These rules are written as enforceable engineering standards. Each should become a lint rule, a CI budget or a code-review checklist item.

Table 2-3 · Thermal and battery engineering rules

Rule	Requirement	Enforcement
T-1	**No frame without a reason.** Render only on input, camera motion, animation or data change. Park the loop otherwise. This is already implemented; it must never regress.	CI test: 0 frames in 20 s idle
T-2	**Hard FPS ceilings per tier**: low 30, mid 45/60 (governor-chosen), high display rate. Idle tiers unchanged.	Tier config table
T-3	**Dynamic resolution always on**: start at the tier ceiling (low DPR 1.25, mid 1.5, high 2.0); step down after 2 s of more than 20% missed frames; step up only after 30–60 s of headroom (existing hysteresis constants).	Governor enabled by default
T-4	**Shadow budget**: one shadow-casting light below the high tier; map ≤ 1024^2 (low) / 2048^2 (mid); refresh only on change; casters limited by size.	Runtime assert in development builds
T-5	**No log-depth, no MSAA render target, no `MeshPhysicalMaterial` on the low tier.** Post-processing limited to one composite pass with FXAA and optional bloom at quarter resolution.	Tier config table
T-6	**Draw and triangle budgets per tier** (Table 2-4), checked by an automated scene census like the one used for this report.	Playwright CI gate

Rule	Requirement	Enforcement
T-7	**Zero per-frame allocations** in loop phases: no `new`, array/object literals, closures, `.map` / `.filter` or string concatenation inside frame callbacks. Use module-scope scratch objects.	ESLint rule on files tagged `@frame`; heap-sampling test
T-8	**Wake-ups are budgeted**: no `setInterval` while parked; all timers go through the scheduler, which suspends on `visibilitychange`, park and `pagehide`.	Code review; ban raw `setInterval`
T-9	**Network is lazy**: no sockets or polling unless the user enables a live feature; exponential backoff with a 5-minute cap when the network is unreachable.	Integration test (0 requests idle)
T-10	**Eco is automatic**: auto-enable after sustained governor floor, and offer it when `prefers-reduced-motion` is set; show a visible chip.	UX acceptance test
T-11	**Texture memory ceiling**: ≤ 64 MB GPU texture memory on the low tier (KTX2 compressed), ≤ 256 MB on the high tier.	Census (renderer.info + estimates)
T-12	**Thermal soak test**: 10 minutes of scripted interaction on the reference low-tier phone, with frame time p95 within 20% of the first minute.	Device-lab release gate

2.6 Device tiers and performance budgets

Table 2-4 · Target configuration and budgets per device tier

Parameter	Low (≤ 4 GB, Mali-G57 / Adreno 6xx)	Mid (6–8 GB, Adreno 7xx / A14–A15)	High (desktop dGPU / A17+)	Today (all tiers)
Max DPR · governor	1.25 · on	1.5 · on	2.0 · on	2.0 · **off**
FPS cap (active)	30	60 (adaptive)	display rate	60
Draw calls / frame (all passes)	≤ 400	≤ 800	≤ 1,500	3,870–5,110
Triangles / frame (all passes)	≤ 0.75 M	≤ 1.5 M	≤ 4 M	3.7–13.3 M
Shadow	1 × 1024², baked statics	1 × 2048²	1 × 4096² + 1 spot	1 dir + 3 spot
Anti-aliasing	FXAA	SMAA / MSAA ×2	MSAA ×4	MSAA (all)
Depth	standard + adaptive near	standard + adaptive near	log or standard	log (all)
Shader programs	≤ 20	≤ 30	≤ 40	68–70
Frame time p95 (active)	≤ 33 ms	≤ 20 ms	≤ 12 ms	n/m (GPU)
Time to first frame (4G, cold)	≤ 4 s	≤ 3 s	≤ 2 s	11.2 s (software GL)
JS heap after GC	≤ 60 MB	≤ 80 MB	≤ 120 MB	41–42 MB ✓

ORDER OF OPERATIONS

Turn on the governor and set the tier policy (PERF-01, -03, -04) first: these are configuration changes, they are low-risk, and they deliver most of the thermal win before launch. Material unification, merging and baked shadows (Table 2-2) are structural, and belong in the Phase 1b bundle and pipeline work, where they will cut the remaining draw calls by a further 5–10×.

SECTION 3

Enterprise-Grade Cybersecurity: The “Bulletproof” Layer

The build already carries an unusual amount of defensive code for a static web page. The IoT bridge in particular is better hardened than most production telemetry clients. The headline protections, though (domain lock, anti-copy, anti-devtools), run entirely in the browser, and an attacker who controls the browser can switch them off. Meanwhile the real attack surface is elsewhere: a large set of URL parameters accepted without authentication, a set of global control APIs, and a launch-day absence of HTTP security headers. This section evaluates each control, models the threats that matter for a university-branded public map, and specifies the header and data-validation layers a V1 launch needs.

3.1 Threat model

A campus map is not a high-value target for data theft: it stores no credentials, sets no cookies, and keeps every user preference in the visitor’s own `localStorage`. Its risk profile is **integrity and trust**. A map published under the SASTRA name is believed. Anything that lets a third party change what the map tells a visitor (where they are, which route is safe, whether an evacuation is under way) becomes a safety and reputational risk, even if no data is stolen.

Table 3-1 · Adversaries and the assets they target

Adversary	Motivation / capability	Asset at risk	Primary vector in this build
Prankster / rumour spreader	Low skill. Shares links on WhatsApp, Instagram or Telegram groups during fests, exams or convocation.	Public trust; physical safety (crowd panic); institutional reputation.	Crafted URL parameters (`?evac=1` , `?geo=` , `?sec=1`)
Cloner / competitor	Copies the single-file build and rehosts or rebrands it.	Intellectual property; brand control.	Any `*.vercel.app` host passes the domain lock; a 468-byte script is all that needs removing.
LAN attacker on campus Wi-Fi	Medium skill. Can advertise mDNS (`*.local`) names, run rogue services, and target students physically on campus.	Integrity of live data: occupancy heat maps, route closures, “live” dashboards.	`?iot=` accepts `*.local` endpoints; telemetry is unauthenticated.
Script injector	Malicious browser extension, compromised third-party script, or future XSS once content becomes API-driven.	Every global control API; DOM integrity.	16 global control APIs (`window.Sastra*` and others), 75 `innerHTML` sinks, no CSP.
Privacy regulator / auditor	Compliance review under India’s Digital Personal Data Protection Act 2023 (DPDP).	Lawful processing of location and voice data.	GPS auto-resume; continuous cloud speech recognition; Google Fonts IP disclosure.

3.2 Evaluation of the existing security controls

Table 3-2 · Control-by-control effectiveness review

Control (build tag)	What it does	Bypass / weakness	Rating	Verdict
Domain lock SH:1 · first script in <head>	Unless the host is `localhost`, `*.localhost` or `*.vercel.app`, and the page is top-level, it calls `document.write("<plaintext hidden>")`, `window.stop()`, wipes the DOM, and throws.	Any attacker-owned `evil.vercel.app` passes the lock. Editing out one script defeats it. **A production custom domain (e.g. `map.sastra.edu`) would be blocked by its own lock.**	▲ BLOCKER	A deterrent, not a control. Allowlist the exact production hosts before launch.
Anti-clickjacking frame-buster + SH:1	`top.location.replace(self)` when framed; SH:1 also wipes the page in any frame.	A sandboxed iframe stops the top-level navigation, but SH:1 still blanks the page, so the net effect holds. JS-only defences fail if JS is blocked, and a meta tag cannot set `frame-ancestors` or `X-Frame-Options`.	● PARTIAL	Replace with the header `frame-ancestors 'none'` plus `X-Frame-Options: DENY`.
Anti-copy capture-phase listeners + CSS	Blocks copy, cut, paste, selectstart, drag and drop; strips the clipboard; Ctrl/⌘ + A, C, V, X, S; `user-select:none!important` on all UI.	Defeated by `view-source:`, Save Page, `curl`, or disabling JS. **Also blocks pasting into the search field**: the paste handler has no exemption for inputs.	● THEATRE	Remove. It costs accessibility and usability and protects nothing.
Anti-devtools	Swallows F12, Ctrl+Shift+I/J/C, Ctrl+U and F11; runs `console.clear()` on every resize; disables the context menu.	DevTools opens from the browser menu. Clearing the console on resize destroys the evidence support staff need, and blocking F11 breaks kiosk fullscreen.	● THEATRE	Remove, and keep the console intact for error telemetry.
WebGL context-loss guard	Wraps `getContext`, listens for `webglcontextlost` / `restored`, and shows a recovery dialog with Reload.	Works as intended. It patches a global prototype, which is acceptable here.	✔ GOOD	Keep. Report context-loss events to monitoring.
XSS hygiene	75 `innerHTML` sinks, mostly static templates. Escape helpers exist in 4 modules. No `eval`, no `new Function`, no inline `on*=` handlers.	Inconsistent escaping: one helper skips `'`. The editor's SVG filter is a blocklist that only rejects `<script`, `onerror` and `onload`.	● FAIR	Safe today because all inputs are bundled. It becomes unsafe the day `campusData` comes from an API.
Viewer-mode data isolation	When `data-viewer="1"` is set, the WorldEditor ignores `localStorage` layouts and uses the embedded payload.	This prevents stored-layout poisoning on public builds.	✔ GOOD	Keep. Also strip the editor code from viewer builds (§4).
Ping deep-links NG:3	The `?ping=x,y,z` parser is regex-anchored and bounds-checked against the campus box.	Hard to abuse: pins can only land on campus.	✔ GOOD	Use it as the template for every other parameter.

Control (build tag)	What it does	Bypass / weakness	Rating	Verdict
IoT bridge MT:1 worker	Validates URL scheme and host, caps message size and batch, rate-limits, checks schema with regex, rejects non-finite values, expires stale data, backs off with jitter, and suspends on hidden/offline/bfcache.	No authentication, integrity or replay protection. `*.local` hosts are accepted from the URL. It connects by default to a placeholder endpoint (SEC-05).	◆ STRONG CORE	Keep the engine. Add the auth and integrity envelope in §3.6.
Content-Security-Policy	**Absent** from the Enterprise build. The older `SastraMap_UltraPerformance.html` in the repository had a meta CSP.	Regression. The `X-Content-Type-Options` meta tag present here is ignored by browsers; only the HTTP header counts.	◆ MISSING	Deliver CSP and the rest of the header set via HTTP (§3.5).

3.3 Prioritised security findings

SEC-01 An unauthenticated URL can declare a campus evacuation

▲ P0 · CRITICAL

EVIDENCE Module EV:1 calls `L(!0)` when `?evac=1` is present. This shows a full-width banner reading **"EVACUATION ROUTE ACTIVE"** and draws an evacuation route. `window.toggleEmergencyMode()` is also exposed globally.

SCENARIO During a fest, someone posts `https://<map-domain>/?evac=1` to a large student WhatsApp group with the text "Fire near the library, follow the route." The page carries the SASTRA name, so it is believed.

IMPACT Crowd panic, injury risk, legal exposure, and lasting loss of trust in the official map for real emergencies.

FIX Remove the URL trigger and the global from production. Emergency state should arrive only as a **signed broadcast** from an authenticated operations console: an Ed25519 signature checked against a public key pinned in the build, with issuer, timestamp and expiry. Show provenance on the banner ("Issued by Campus Security · 14:05") and a distinct "DRILL" style. Track the change in the release checklist.

SEC-02 Domain lock both blocks the real production domain and allows every Vercel tenant

▲ P0 · LAUNCH BLOCKER

EVIDENCE SH:1 allows only `localhost`, `*.localhost` and `/(^|\.)vercel\.app$/`. Every other hostname gets a wiped DOM and the error "SastraMap: blocked host".

IMPACT If the map launches on a university domain, the page is blank for every visitor. If it stays on Vercel, any third party can host a byte-identical clone under its own `*.vercel.app` name and the lock lets it through.

FIX Allowlist exact hostnames (e.g. `map.sastra.edu` and one named preview host). Add a launch-day smoke test from the production URL. Treat the lock as a soft deterrent: real control comes from a licence notice, server-side delivery, CSP and periodic clone monitoring.

SEC-03 No Content-Security-Policy, and meta-tag "headers" that browsers ignore

P1 · HIGH

EVIDENCE The Enterprise build has no CSP of any kind. The repository's earlier UltraPerformance build shipped `default-src 'none'`, which was probably dropped because it blocked the new WebSocket and blob workers. `<meta http-equiv="X-Content-Type-Options">` has no effect; only the HTTP header is honoured.

FIX Deliver the header set in Table 3-4 from the CDN or edge. Roll out CSP in `Report-Only` mode for one week, then enforce it.

SEC-04 Location spoofing: `?geo=lat,lon` silently moves the "You are here" origin

P1 · HIGH

EVIDENCE The GPS module (`c14`) replaces its projection origin (default 10.7296°N, 79.0194°E) with any finite pair from `?geo=` . There is no bounds check and no on-screen indication.

SCENARIO A link with `?geo=10.7305,79.0213` shifts every GPS fix by roughly 100–200 m. A visitor's dot, and every route drawn from it, now starts in the wrong place, with no warning.

FIX Remove the parameter from production builds. If it is needed for surveying, require it to fall within ±0.005° of the campus centroid, accept it only together with a signed debug token, and show a persistent "calibration override" badge.

SEC-05 IoT bridge connects by default to a placeholder endpoint and trusts `*.local` hosts

P1 · HIGH

EVIDENCE MT:1 enables "Live IoT Twin" unless the stored preference is `"0"` , and 1.5 s after `campus:ready` it connects to `wss://sastra-iot-telemetry.local` . **In a single profiling session the egress proxy recorded 18 rejected connection attempts to `sastra-iot-telemetry.local:443` .** A `?iot=` override is accepted when its host equals the page host, is localhost, or ends in `.local` .

IMPACT Every visitor makes doomed DNS and mDNS lookups and reconnect attempts with backoff up to 60 s, which costs radio wake-ups and battery. A campus-LAN attacker serving a `*.local` endpoint (fully practical on `http://` deployments and kiosks, harder on HTTPS) can feed fabricated occupancy and `NAV` / `EDGE` closures that re-route pathfinding.

FIX Ship V1 with IoT **off** and no default endpoint. Remove `.local` from the allowlist. Make `connect-src` the authoritative endpoint allowlist. Add authentication and signed frames (§3.6).

SEC-06 Sixteen global control APIs are exposed to any script on the page

P1 · HIGH

EVIDENCE Measured at runtime: `SastraTwin` , `SastraAcoustics` , `SastraLOD` , `SastraNG` , `SastraSettingsNG` , `SastraTheme` , `SastraPing` , `SastraWarp` , `SastraHolo` , `SastraXRay` , `SastraGrandTour` , `SastraGTAWalk` , `SastraEnterpriseUI` , `SastraSmartCampus` , `debugTime` , plus `toggleEmergencyMode` . `SastraTwin.inject()` pushes arbitrary telemetry text into the IoT worker.

FIX In production, expose a single frozen read-only `SastraMap.state()` . Keep mutating APIs behind a build flag. Never expose emergency or telemetry writers.

SEC-07 69 URL parameters, most of them debug and tuning switches, are live in production

P2 · MEDIUM

EVIDENCE See Appendix A for the full inventory. Examples: `?fps=1` (1 fps cap), `?rest=0` (never park the loop), `?dpr=4`, `?msaa=8`, `?gfx=high` (force the high tier on phones), `?shadows=live`, `?texcache=clear`, `?admin=1` (performance HUD showing the unmasked GPU renderer string, a fingerprinting aid), `?sec=1` (opens the Security View).

IMPACT A shared link can turn a phone into a hand-warmer or make the map appear broken, and the visitor has no way to know why.

FIX Use a production allowlist. Only share-link parameters survive (`ping`, the place hash, `lang`, `route`), and numeric values are clamped. Everything else is ignored unless the page runs on localhost or a short-lived signed `debug` token is present.

SEC-08 The public “Security View” discloses campus security posts

P2 · MEDIUM

EVIDENCE Module c11 lists and animates “Main Gate & guard kiosks”, “Security huts”, “Security Rest House”, “Campus gates 2–5” and “Dispensary”, reachable from the UI and via `?sec=1`.

FIX Run a governance review with Campus Security. Publish public-safety points (gates, dispensary, assembly points, AED locations) and withhold internal security infrastructure.

SEC-09 HTML sinks are ready to become XSS once data is API-driven

P2 · MEDIUM

EVIDENCE 75 `innerHTML` assignments. Escaping is duplicated across 4 modules with different coverage. The WorldEditor’s SVG “sanitizer” accepts markup that starts with `<svg` and rejects only `<script`, `onerror` and `onload`, so `onbegin`, `onfocus`, `onmouseover` and `javascript:` URLs all pass.

FIX Use one shared `escapeHTML` / `html``` tagged-template utility. Use `textContent` by default and DOMPurify for any rich text. Enforce Trusted Types (`require-trusted-types-for 'script'`) after a report-only period.

SEC-10 Anti-copy and anti-devtools measures harm users and protect nothing

P2 · MEDIUM

EVIDENCE Paste is blocked even in the search box, so a room code such as “TDC 207” copied from a timetable cannot be pasted. F11 fullscreen is blocked. Select-all and text selection are disabled, which affects assistive-technology users. The keys I, J, N, O, U and the digit keys are swallowed at capture. The console is cleared on every resize.

FIX Remove all of it. If IP protection is the goal, rely on a licence notice in the source, a visible “© SASTRA · Created by Sakthi” mark (already present), and server-side controls.

SEC-11 **Voice assistant: no link-based microphone hijack, but always-on cloud listening needs consent** — ● P2 · PRIVACY

VERIFIED	**No URL parameter can start the microphone.** `?voice=0` and `?audio=0` can only disable it. Listening requires the user to switch on "Spatial Audio & AI Voice" in Settings, plus the browser's own permission prompt. The state is not persisted across visits. Recognition pauses when the tab is hidden and gives up after 5 rapid failures.
GAP	On desktop (fine pointer), turning it on starts **continuous** wake-word listening ("Sakthi", `en-IN`) with no idle timeout. The Web Speech API streams audio to the browser vendor's cloud recogniser, which the UI never discloses.
FIX	Make push-to-talk the default everywhere. Auto-stop after 60 s idle. Show a first-use privacy notice naming the recogniser. Send `Permissions-Policy: microphone=(self)`.

SEC-12 **Geolocation resumes automatically on return visits** — ▽ P3 · PRIVACY

EVIDENCE	If the permission is already `granted`, high-accuracy `watchPosition` starts automatically about 0.9 s after load, once per session. Positive: no code path sends location off the device.
FIX	Ask for an explicit "Locate me" tap each session, show a clear indicator while tracking, and publish a DPDP-aligned privacy notice.

SEC-13 **Dependency and global-patching hygiene** — ▽ P3 · LOW

EVIDENCE	three.js **r128** (2021) is embedded and no longer receives fixes. Google Fonts is hot-linked (4 families, 17 weights), which discloses visitor IPs to a third party and complicates CSP and COEP. Global patches: `Math.random` is swapped 60 times; `document.readyState` is redefined; trusted `DOMContentLoaded` / `load` events are swallowed and re-dispatched; `HTMLCanvasElement.prototype.getContext` is wrapped.
FIX	Self-host subset WOFF2 fonts. Plan a three.js upgrade (§4.6). Publish an SBOM. Confine RNG seeding to module-local generators instead of the global.

3.4 URL parameter attack-surface analysis

The build reads **69 distinct query parameters** through about 20 separate parsing helpers, one per module. None of them are authenticated. The table classifies them by what an attacker can achieve with a link alone. The complete inventory is in Appendix A.

Table 3-3 · Link-only attack classes

Class	Parameters	What a malicious link achieves	Severity
Safety / social engineering	`evac=1`	Fake evacuation banner and route under the SASTRA brand.	▲ CRITICAL
Location spoofing	`geo=lat,lon`	Shifts the user's real GPS position on the map; misroutes visitors.	◆ HIGH
Data injection	`iot=wss://host.local`, `iot=1`	Points the twin at an attacker-controlled feed (LAN, `.local`), giving fake crowding and closures.	◆ HIGH

Class	Parameters	What a malicious link achieves	Severity
Information exposure	`sec=1`, `admin=1`	Opens the security-posts panel; reveals the GPU model and performance internals.	● MEDIUM
Battery and thermal griefing	`fps`, `rest`, `active`, `dpr`, `msaa`, `gfx`, `lock`, `shadows`, `walkshadow`, `hycell`, `lodreach`	Forces maximum quality, disables the idle governor, or caps to 1 fps. The map looks broken or the phone overheats.	● MEDIUM
Misinformation (cosmetic)	`hour`, `weather`, `os`, `pal`, `tdc`, `pins`	Night at noon, rain on a clear day, dashboards opened with simulated data presented as live.	▽ LOW
Feature kill-switches	`voice=0`, `audio=0`, `menu=0`, `ng=0`, `link=0`, `poi=0`, `l9=0`, `route=0`, …	Disables UI such as the settings menu, so support staff see a “broken” map.	▽ LOW
Microphone hijack	none	**Not possible.** No parameter enables listening; a user gesture and browser permission are both required.	✔ VERIFIED SAFE

DESIGN RULE FOR EVERY FUTURE PARAMETER

Copy the pattern the `ping` parser already uses. Use an anchored regex. Coerce numbers. Range-check against campus bounds. Make the effect visible on screen. Never let a parameter change safety-relevant state (emergencies, closures, user position) or performance policy. Parameters are untrusted input from whoever wrote the link.

3.5 Recommended HTTP security headers

Every header below must be sent **as an HTTP response header** from the CDN or edge (Vercel `headers`, Cloudflare Transform Rules, or Nginx `add_header … always`). `<meta http-equiv>` cannot deliver `frame-ancestors`, `X-Frame-Options`, `X-Content-Type-Options`, HSTS, COOP or COEP.

Table 3-4 · Production header set for the map origin

Header	Value (V1)	Purpose and notes
`Content-Security-Policy`	`default-src 'none'; script-src 'self' 'nonce-{N}'; style-src 'self' 'nonce-{N}'; img-src 'self' data: blob:; font-src 'self'; connect-src 'self' https://api.<domain> wss://live.<domain>; worker-src 'self' blob:; media-src 'self' blob:; manifest-src 'self'; frame-ancestors 'none'; base-uri 'none'; form-action 'none'; object-src 'none'; upgrade-insecure-requests; report-to csp`	Restricts code, styles, workers and sockets to known origins. Two build changes are needed: the packed loader must copy the nonce onto each `<script>` and `<style>` element it creates (27 script chunks, 23 style blocks), or the bundle must move to external hashed files with `script-src 'self'`. Start with `Content-Security-Policy-Report-Only`.
`…; require-trusted-types-for 'script'; trusted-types sastra`	(appended in Phase 1b)	Forces every `innerHTML` through one audited policy. Enable after the 75 sinks are routed through it.

Header	Value (V1)	Purpose and notes
`Strict-Transport-Security`	`max-age=63072000; includeSubDomains; preload`	Two years. Only add `includeSubDomains` and `preload` on the apex once every SASTRA subdomain serves HTTPS; otherwise scope HSTS to the map host.
`X-Content-Type-Options`	`nosniff`	Header form; the existing meta tag is ignored.
`X-Frame-Options`	`DENY`	Legacy anti-framing alongside `frame-ancestors`.
`Referrer-Policy`	`strict-origin-when-cross-origin`	The current meta `no-referrer` is also acceptable. Either way, place slugs in URLs never leak to third parties.
`Permissions-Policy`	`geolocation=(self), microphone=(self), camera=(self), xr-spatial-tracking=(self), accelerometer=(self), gyroscope=(self), magnetometer=(self), fullscreen=(self), clipboard-write=(self), payment=(), usb=(), serial=(), hid=(), bluetooth=(), display-capture=(), browsing-topics=()`	Limits powerful features to the map's own origin. Camera and XR are needed for the AR portal; everything unused is denied.
`Cross-Origin-Opener-Policy`	`same-origin`	Isolates the browsing context group.
`Cross-Origin-Embedder-Policy`	`require-corp` (or `credentialless`)	With COOP this makes the page `crossOriginIsolated`, which unlocks MT:1's existing `SharedArrayBuffer` + `Atomics` fast path for the navigation and IoT workers (today it always falls back to message copies). Self-hosted fonts are required, because Google Fonts would be blocked.
`Cross-Origin-Resource-Policy`	`same-origin`	Stops other sites embedding the bundle and assets.
`Reporting-Endpoints`	`csp="https://<report-endpoint>/csp"`	Collects CSP, COEP and deprecation reports during rollout.
`Cache-Control`	HTML: `no-cache`; hashed assets: `public, max-age=31536000, immutable`	See the pre-flight checklist (§6) for the full caching matrix.

3.6 WebSocket and IoT data-validation strategy

The client-side bridge in MT:1 is a strong foundation. Before any live campus data is connected, the controls below should be recognised and kept:

Table 3-5 · Controls already implemented in the IoT worker

Layer	Implementation in the current build
Transport	`ws://` / `wss://` scheme check; `ws://` refused on HTTPS pages (except localhost); non-printable characters in the URL rejected.
Isolation	Parsing runs in a dedicated Worker, so a malformed or flooding feed cannot block rendering. A protocol version and hash handshake rejects stale worker files.
Volume limits	Frames over 64 KiB dropped; at most 256 readings per batch; 600 readings/s token bucket; binary frames rejected.
Schema checks	`nodeId` matches `^[A-Za-z0-9][A-Za-z0-9 _.:\-]{0,47}$`; `metric` matches `^[A-Za-z][A-Za-z0-9_]{0,31}$`; `value` must be a finite number; `ts` must be finite.
Semantics	Occupancy clamped to 0–100; crowd ratio in [0, 1]; at most 64 rooms per building and 48–96 buildings; stale readings expire after 120 s; route closures auto-expire after 120 s.
Resilience	Exponential backoff from 1 s to 60 s with 50–100% jitter; 12 s connect timeout; suspends when the tab is hidden, the device is offline, or the page is in the back-forward cache.

Gaps to close before connecting real sensors

1. **Authenticate the socket.** The client fetches a short-lived (≤ 5 min) signed ticket over HTTPS and presents it in the `Sec-WebSocket-Protocol` header. The gateway validates the ticket and checks the `Origin` header against an allowlist. Allow `wss://` only.
2. **Wrap every frame in a versioned envelope**: `{v, seq, ts, src, payload}`. Reject frames whose `seq` goes backwards (replay) or whose `ts` is more than 30 s from server time.
3. **Sign safety-critical messages.** Closures (`NAV` / `EDGE`), evacuation state and broadcast notices carry an Ed25519 signature that the worker verifies against a pinned public key, with rotation via a signed key list. A compromised broker then still cannot re-route people.
4. **Enforce a sensor registry instead of fuzzy matching.** Today `resolve()` upper-cases the node id, strips trailing room digits and maps aliases (`JNC` / `SCBT` → `jvc`), so any plausible string attaches to a building. In production, accept only node ids registered in the registry, with per-metric unit and range tables.
5. **Aggregate before broadcast.** Clients receive building-level aggregates, never raw device data. Crowd figures go out only above a minimum group size (k-anonymity, e.g. $k \geq 10$) so the map can never be used to locate an individual.
6. **Detect anomalies server-side.** Rate-of-change limits (e.g. 0 → 100% in one tick is quarantined), cross-sensor plausibility checks, and dead-man timers that mark a feed "stale" in the UI.
7. **Topology.** Sensors → edge gateway (mTLS, device certificates) → MQTT broker with per-topic ACLs → stream validator and aggregator → read-only WebSocket fan-out gateway (behind the CDN, with per-IP rate limits) → browser. The browser never talks to a broker or a device.

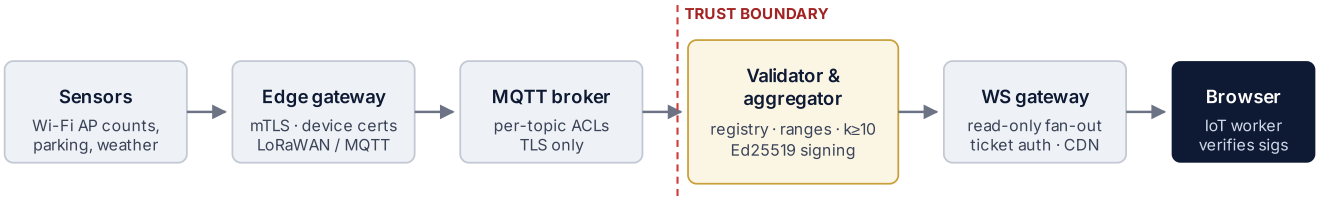


Figure 3-1. Target telemetry topology. The browser-side IoT worker stays as the last line of defence; authority moves to a server-side validator that signs what it publishes.

SECTION 4

Code Architecture & Scalability

SastraMap reached its present feature density through seven generations of build-time layering. Each generation (Optimized V1 → Cine Tour → Emergency → Digital Twin → Multithread → NextGen → Enterprise) injected new "shell" scripts that wrap the previous generation's internals. This layering has been remarkably productive and is now the main constraint on scaling. This section documents the architecture as it actually is, then sets out the target architecture, the data/API blueprint, and the pathfinding roadmap.

4.1 The architecture as built

GENERATION	MODULES (BUILD TAGS)	SIZE (BROTLI)
Enterprise	EN:1 action button · EN:2 Smart-Campus suite (eco, timeline, transit, indoor, notices, heat map, XR)	15 KB
NextGen	NG:0 kernel · NG:1 settings · NG:2 themes · NG:3 ping · NG:4 warp · NG:5 holograms · NG:6 X-ray · NG:7 tour · NG:8 walk	72 KB
Multithread / Twin	MT:1 nav and IoT workers + heat map · MT:2 acoustics/occlusion · MT:3 LOD · DT/EV:1 emergency evacuation	36 KB
Feature modules	search · routes · GPS · POI · radar · weather · DOF · gates · zones · AR/XR · Campus OS · palette · settings (c04–c26)	212 KB
Engine core	c02 renderer, scene, loop, camera, procedural campus, audio, voice · c06 records and cards · c03 WorldEditor	364 KB
Platform shell	SH:1 domain lock · anti-copy · IB:1–3 boot gate · texture cache (IndexedDB) · fflate unpacker · three.js r128	133 KB

Modules communicate through a private namespace object (window._N6, deleted after boot) with 1–3-letter keys; later layers wrap earlier hooks (e.g. the per-frame hook SW.H is re-wrapped 23 times).

Figure 4-1. Layer cake of the Enterprise build. Sizes are Brotli-11 per module, measured on the decoded payload.

Delivery mechanics

- **One 1,357,907-byte HTML file.** It contains 21 inline shell scripts, 2 style blocks, and a `text/plain` payload (`#uoZ`) holding 805,565 bytes packed 7 bits per character. That payload inflates (fflate) to 2,586,865 characters: three.js r128, 26 application modules and the 61 KB layout JSON.
- **Gated execution.** The IB:1 shell overrides `document.readyState` , holds back the trusted `DOMContentLoaded` / `load` events, waits for fonts and one idle slot, then runs the 27 chunks one per `MessageChannel` tick so the splash keeps painting. Lifecycle events are replayed afterwards.
- **Idempotent modules.** Every module first deletes any DOM and CSS it previously created (by id) and then rebuilds it. That makes it safe to re-run, and also hides duplicate-injection bugs.
- **Kernel.** NG:0 introduced `ngx` , an actual plugin registry: `register` , `set` , `isOn` , `onFrame` , `onPost` , `mainPass` , `awake` , `wake` , shader `warm` , `purge` , `toast` . Feature flags persist under `sastra.ng.*` . This is the seed of the target architecture.
- **Events.** `campus:ready` , `campus:frame` , `sastra:route` , `sastra:card` and `sastra:origin` form an informal event bus.

Health metrics (static and runtime)

Table 4-1 · Code-health indicators

Indicator	Value	Interpretation
Application JavaScript (minified, excluding three.js)	≈ 2.30 MB	≈ 690 KB Brotli. Large for a map; 30% of it is the WorldEditor that viewers never use.
Modules / build tags	47	26 packed chunks + 21 inline shells. The authoring source and the `*.build.cjs` scripts are **not in the repository**.
`try` / `catch` blocks · of which empty	1,086 · 553	Very defensive, but half of all failures are silently swallowed and there is no error reporting.
`addEventListener` vs `removeEventListener`	455 vs 55	Fine for a single-page lifetime; a liability once panels mount and unmount dynamically.
Runtime DOM elements · JS event listeners (idle)	1,507 · 584	Measured via CDP `Performance.getMetrics`.
Runtime-injected `<style>` blocks · `!important`	23 · 277+	Specificity arms race between layers; 37 distinct z-index values up to 2,147,483,001.
Query-string parsers	20	One per module; 69 parameters, none centrally validated.
Global `Math.random` swaps	60	Seeded procedural generation implemented by temporarily replacing a global.
Accessibility hooks	290 `aria-*` · 49	Strong: ARIA roles and labels, 49 `prefers-reduced-motion` branches, a high-contrast mode, Tamil text.
Duplicate implementations	≥ 4 classes	Two A* path finders, four HTML-escape helpers, twenty query parsers, three POI catalogues with different id schemes.

Assessment

STRENGTHS TO PRESERVE

- A performance-first mindset: loop parking, idle FPS tiers, a texture cache, workers, geometry de-duplication (“ddPool”).
- Graceful degradation everywhere: feature detection, fallbacks, and a WebGL context-loss recovery dialog.
- A real feature-flag and plugin kernel (`ngx`) with toasts, warm-up and awake management.
- Bilingual (English/Tamil) content model and strong accessibility intent.
- Honest labelling of simulated data (“Simulated”, “demo feed”, “mock layout”).

STRUCTURAL RISKS

- **The build artifact is the source of truth.** The repository holds only built HTML. Without the authoring sources and build scripts the project has a bus factor of one.
- **Coupling through minified keys** (`SW.rk` , `SW.H` , `SW.J`). A rename in one generation silently breaks a later one, and empty catches hide the breakage.
- **Order-dependent wrapping.** Behaviour depends on which layer wrapped a hook last.
- **Dead and phantom references:** an optional `player.glb` whose loader isn’t bundled, `audio/*.mp3` and `images/velaa_logo.jpg` absent from single-file deploys, and `nav.worker.js` / `iot.worker.js` requested first, failing, then rebuilt from blobs.
- **No tests or CI** in the repository; no observability.

4.2 Target architecture: state, DOM and modularity

The recommendation is **evolution, not rewrite**. The `ngx` kernel already embodies the right idea, so formalise it and move the codebase onto standard tooling one layer at a time.

Table 4-2 · From current pattern to target pattern

Concern	Today	Target (V1.x)
Source & build	Generational `*.build.cjs` scripts patch prior HTML; single-file output.	TypeScript ES modules in a monorepo, built with Vite/Rollup into hashed chunks. Source, build and tests all versioned in Git with CI (lint, type-check, unit tests, bundle-size gate, Playwright smoke tests).
Module contract	IIFE per module; reads and writes `window._N6` keys; wraps hooks.	A typed plugin interface: `{ id, deps[], init(ctx), onFrame?, onPost?, dispose() }`. The kernel resolves order from `deps`, wraps each plugin in an error boundary that reports to telemetry and disables the plugin rather than the app, and exposes services through typed context instead of globals.
State	Scattered module locals; DOM classes as state (`body.gx-eco`, `ev-on`, `ct-on` …); `localStorage` read ad hoc under 26 keys.	One observable store (signals or a vanilla store) for selection, camera mode, panels, route, settings, device tier, emergency state. Persistence through one versioned `storage` service (single key namespace with schema version and migration). DOM classes are derived from state, never the other way round.
URL state	20 parsers, 69 parameters.	One `urlState` module: an allowlist, typed coercion and clamping, production vs development profiles, and two-way sync with the store for shareable links.
UI / DOM	HTML strings via `innerHTML`; 23 injected style blocks; global CSS with `!important`.	Lightweight components (Lit or Preact) with scoped styles, design tokens (colour, spacing, type, z-index scale with about 6 named layers), a Trusted-Types-compatible template helper, and a component inventory with Storybook-style visual tests.
Rendering	One module owns the loop; others hook `SW.H` / `onFrame`.	A frame scheduler with explicit phases (input → simulate → cull → shadow → render → post → UI). Each phase has a budget and per-plugin timing, visible in the admin HUD.
Errors	553 empty catches; `console.clear()`.	Structured error reporting (e.g. Sentry with source maps), a privacy-safe RUM beacon (FPS buckets, tier, long tasks, context losses), and “report a problem” in the UI.

4.3 Blueprint: from static `campusData` to an API-driven platform

Current data inventory

Table 4-3 · Where campus data lives today

Dataset	Location	Size	Content
Academic records (`campusData`)	c06	32 KB	16 buildings (VV, VKJ, SOC, LTC, SASHE, TDC, TIFAC, CV, SOE, Chanakya, Poly, ASK1–3, SCBT, NMV), 29 floors, 257 room entries; branches, labs, programmes, capacity, highlights.
Building geometry and metadata	c02	inline	Procedural footprints (`parts[].poly` , floors, wall and roof style), English and Tamil names and descriptions, categories, label flags.
Layout payload (`#sathizz-map-data` , v7)	HTML tail	61 KB	41 building transforms, 290 custom placements, 551 deleted props, visual-effects preset, build stamp `Bmuds6ios-9kbp` .
Navigation graph	MT:1, c16	≈ 6 KB	155 nodes, 171 edges, 4 edge classes, cost table `[1, 1, 1.1, 1.35, 1.6, 1.25]` ; route targets for 14 academic facilities (6 with explicit door anchors).
POI catalogues	c04, c07, c11, c21, c23, NG:5	mixed	Gates, zones, landmarks and security points, food, restrooms, parking bays, event holograms (Kuruksastra, Daksh).
Simulated feeds	EN:2, c23	generated	Energy, transit, notices, crowd heat map, parking. Labelled “simulated” in the UI.

The same building has different identifiers in different modules: `vv-auditorium` (geometry), `VV` (records), `vidyut_vihar` (navigation and IoT). Alias tables (`VKJ→vishwakarma_joth` , `JNC/SCBT→jvc`) are duplicated between the UI and the worker. **The first step to an API is a single canonical identifier per entity.**

Target domain model

Table 4-4 · Core entities (canonical slug ids, bilingual fields as `{en, ta}`)

Entity	Key fields
Building	`id` , `codes[]` (VV, VV-AUD …), `name{en,ta}` , `category` , `footprint` (GeoJSON Polygon, WGS84 plus local metres), `floors` , `height` , `entrances[]` (each linked to a NavNode), `media[]` , `departments[]` , `hours` , `accessibility`
Floor / Room	`floor{key, level, name}` ; `room{code, type (class, lab, office, washroom …), capacity, accessible, bookable}`
POI / Facility	`type` (gate, food, restroom, ATM, parking, bus, medical, AED, assembly point), `location` , `hours` , `contact` , `visibility` (public, staff, security-only)
NavNode / NavEdge	`class` (road, footpath, corridor, stairs, ramp, lift), `accessible` , `surface` , `slope` , `lit` , `openHours` , `floorLink`
Event / Notice	`title{en,ta}` , `venue → Building/Room` , `start` , `end` , `audience` , `publisher` , `signature` (for safety notices)
Sensor / Reading / Closure	Sensor registry (`nodeId` , metric, unit, range, owner); aggregated readings; signed closures with expiry

API surface (v1)

Table 4-5 · Public read API (all GET, cacheable, ETag-validated)

Endpoint	Purpose · caching
`/v1/manifest`	Dataset versions and content hashes · `no-cache`, about 1 KB
`/v1/buildings` · `/v1/buildings/{id}`	Records, footprints and media references · `immutable` via hashed URL
`/v1/buildings/{id}/floors/{level}/rooms`	Room directory per floor · lazy-loaded when a card opens
`/v1/pois?type=&bbox=`	Facilities, filtered by visibility
`/v1/search?q=&lang=`	Server-side fuzzy search (room codes, Tamil names), with the client index as offline fallback
`/v1/nav/graph?profile=walk|wheelchair|night`	Versioned routing graph per profile
`/v1/events` · `/v1/notices`	Time-bounded content · `max-age=60, stale-while-revalidate`
`wss://live…/v1/stream`	Aggregated, signed live state (occupancy, parking, closures, alerts)

Migration path

1. **M1 · Extract (2 weeks).** At build time, pull every dataset out of the modules into `/data/*.json`, each with a JSON Schema and one canonical id namespace plus an alias table. CI validates the schemas and referential integrity (every entrance resolves to a NavNode, every room to a floor).
2. **M2 · Consume (2 weeks).** Modules read through a typed `DataRepository`. The client fetches `manifest` and then hashed datasets, and falls back to the embedded snapshot when offline. A Service Worker serves stale-while-revalidate, and IndexedDB persists the data.
3. **M3 · Govern (4–6 weeks).** A headless CMS (Directus, Strapi or Payload on PostgreSQL + PostGIS) with SASTRA SSO, roles (Estate Office, Registrar, Departments, Security), approval workflow and audit log. Publishing writes new immutable JSON to the CDN and bumps the manifest.
4. **M4 · Go live (Phase 2).** Events, notices and closures APIs, plus the signed live stream (§3.6).

> **WHY STATIC-FIRST**
>
> Campus data changes daily at most, and visitors spike around admissions, fests and convocation. Publishing immutable JSON to a CDN gives near-zero origin load, offline resilience, and simple cache invalidation by manifest hash. The live API is reserved for data that is genuinely live.

4.4 A* pathfinding readiness and NavMesh strategy

What already exists

Table 4-6 · Routing components in the build

Component	Implementation	Assessment
Worker A* (MT:1 `nav.worker`)	CSR adjacency in typed arrays; binary heap in `Int32Array` / `Float64Array`; generation-stamped visited sets (no per-query clearing); admissible heuristic (Euclidean × minimum class cost); start and goal projected onto the nearest edge; building obstacle boxes with margin; node and edge closures with 120 s TTL; `SharedArrayBuffer` / `Atomics` query path when cross-origin isolated; protocol and hash handshake.	✔ PRODUCTION-GRADE CORE
Main-thread A* (c16 route module)	Array-of-arrays heap; same cost table; fillet smoothing (radii `[0, 6, 3.5, 3, 3, 3]`); route targets for 14 facilities, 6 with explicit door anchors; drives the drawn route ribbon.	● DUPLICATE
Evacuation (EV:1)	Consumes route paths from the shared path service to draw the evacuation route from the open card to the Main Gate assembly area.	● NEEDS SIGNED TRIGGER
Graph data	155 nodes, 171 edges, edge classes 1/2/4/5 (105/38/11/17 edges), hand-authored coordinate arrays in code.	◆ NEEDS TOOLING
Accessibility	“Wheelchair Routes” tints step-free paths visually; the router takes no accessibility profile.	◆ GAP
Indoor	“Deep Indoor Navigation” (EN:2) runs on a mock TDC layout.	● PROTOTYPE

Verdict. The algorithmic core is ready for V1 outdoor routing. Before launch: merge onto one implementation (the worker), give the main thread a synchronous fallback that shares the same graph data, and add an accessible-routing profile. At campus scale the graph is tiny, so a query costs well under a millisecond. The nearest-edge search is an O(E) scan, which is fine at 171 edges but needs a uniform grid or R-tree once indoor graphs push E into the tens of thousands.

NavMesh strategy (Phase 2–3)

1. **Hybrid model.** Keep the semantic network graph authoritative for roads and footpaths, where it produces better turn-by-turn instructions. Use navigation meshes only where movement is genuinely two-dimensional: plazas, lawns, car parks, building interiors.
2. **Offline baking.** Generate meshes with Recast (`recast-navigation-js`, WASM) at build time from footprints and floor plans, per floor. Ship them as compact binary tiles. Run Detour queries in the existing navigation worker.
3. **Hierarchy.** Portals (doors, stairs, lifts, ramps) connect floor meshes to the outdoor graph. Long routes plan on the portal graph (HPA*) and refine locally, then apply the funnel algorithm for smooth paths.
4. **Profiles.** `walk`, `wheelchair` (no stairs, slope ≤ 1:12, prefer lifts), `night` (prefer lit paths), `visitor` (avoid restricted zones). These are implemented as cost tables per edge attribute, so the existing class-cost mechanism carries over directly.
5. **Dynamic state.** Signed closures and optional aggregated crowd costs feed the same worker closure API that already exists.

6. **Quality assurance.** A golden-route suite of about 200 origin/destination pairs with expected length bounds, property tests (no closed edge used, path continuity, accessibility constraints honoured), and a performance budget of under 2 ms per query in the worker at 50k edges.

4.5 Bundle architecture for scale

Table 4-7 · Proposed chunking (Brotli sizes measured on today's code)

Chunk	Contents	Today (br)	Loading policy
`vendor-three`	three.js (r128 today)	123 KB	Immutable; survives app releases
`core`	Loop, renderer, camera, input, campus world, cards, search	≈ 200 KB	Critical path
`data`	Manifest + datasets	≈ 25 KB	Critical path, cached
`features-*`	Routes, GPS, radar, weather, themes, tour, walk, holograms	≈ 150 KB	Lazy, on first use or idle
`xr`	AR / XR portal (c25, EN:2 XR)	≈ 15 KB	On tap, only if `navigator.xr`
`twin`	IoT bridge, heat maps, Campus OS	≈ 45 KB	Only when Live Twin is enabled
`editor`	WorldEditor (c03)	181 KB	**Excluded** from public builds

Net effect: the critical-path transfer drops from **944 KB** (today's Brotli'd HTML) to roughly **350 KB**. That makes first-visit load on a 4G phone several seconds faster and repeat visits near-instant: immutable caching plus V8 code caching, which inline scripts cannot use.

4.6 Engine currency: three.js r128

r128 dates from 2021. Upgrading to a current release brings `BatchedMesh` (thousands of different meshes in one draw call), much smaller tree-shaken ES module builds, built-in KTX2/Meshopt loaders, improved shadow-map and colour-management defaults, and a path to `WebGPURenderer`. The migration touches colour management (`outputEncoding` → `outputColorSpace`), lighting units (physically-correct lights by default since r155), and the many `onBeforeCompile` shader patches (31 sites), which must be re-validated. Schedule it as a dedicated Phase 1b work package after launch, behind the visual-regression suite. Do not attempt it in the launch window.

SECTION 5

Future-Proof Feature Roadmap

Much of the roadmap is already prototyped in the build. Heat maps, transit, notices, an energy dashboard, a Grand Tour, AR and tabletop modes, and a natural-language “spatial intent” palette all exist, behind simulated feeds or feature flags. So the roadmap is less about inventing features and more about **graduating** them: give each one real data, governance and performance budgets, and launch only what is ready.

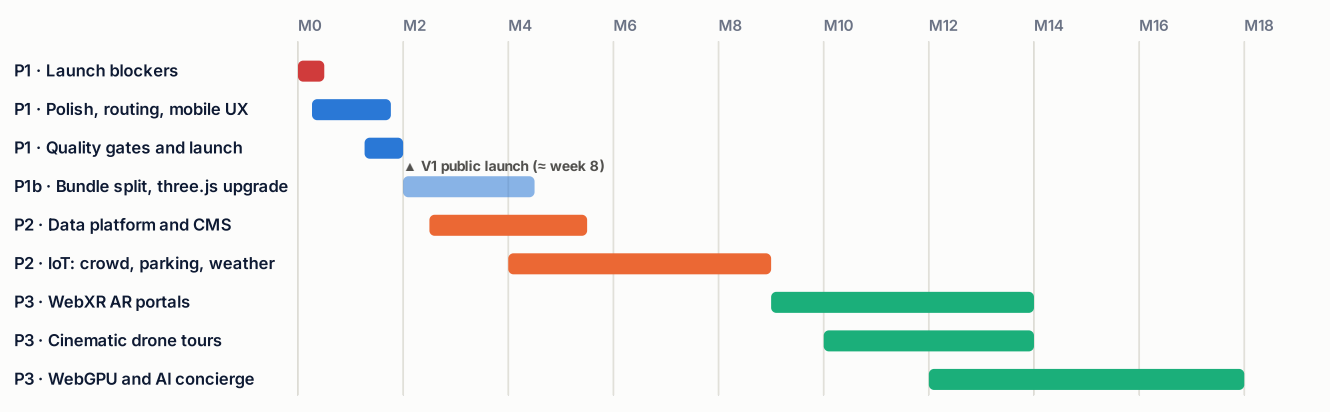


Figure 5-1. Phased delivery over 18 months. Phase 1 is red/blue (red marks launch blockers), Phase 2 orange, Phase 3 green. Durations assume one lead developer plus part-time design and content support; they scale linearly with team size only for the data and IoT streams.

5.1 Phase 1: The Perfect V1 Launch (weeks 0–8)

1A · Launch blockers (weeks 0–2)

Ref	Action	Acceptance test
SEC-01	Remove the `?evac=` trigger and the `toggleEmergencyMode` global from public builds.	The link does nothing.
SEC-02	Allowlist the exact production hostnames in the domain lock.	Smoke test on the production URL.
SEC-05	IoT twin off by default; no placeholder endpoint.	Zero socket attempts in a 10-minute session.
SEC-07	Production URL-parameter allowlist with clamping.	`?fps=1&dpr=4&gfx=high` is ignored.
SEC-03	HTTP security headers, with CSP in report-only mode.	securityheaders.com grade A; no CSP violations.
PERF-01..05	Adaptive resolution governor on; log-depth off on mobile; shadow-caster culling; low-tier post-processing policy (§2).	Meets the §2.6 budgets on the reference low-tier phone.
SEC-10	Remove anti-copy, anti-devtools and paste blocking.	A room code can be pasted into search.

Ref	Action	Acceptance test
OPS	Fix the missing `images/velaa_logo.jpg`; deploy or stop requesting `nav.worker.js` / `iot.worker.js`; add error reporting.	Zero 404s; errors visible in the dashboard.

1B · UI polish (weeks 2–6)

- **Calm first impression.** The current HUD can show brand, tools, view bar, minimap, compass, radar, search, dock, floating action button, Campus OS pill and tour button at once. Define a **visitor default** (search, locate-me, one menu) and a **power mode** for everything else. On phones, at most 3 persistent controls outside the bottom sheet.
- **One design-token system** (colour, type scale, radii, elevation, z-index layers) across all 47 modules. Inter and Noto Sans Tamil, self-hosted and subset.
- **One language switch** (English / தமிழ்) that drives every string, including toasts and cards. Tamil content already exists for names and descriptions.
- **First-run onboarding** in three steps (search, locate, explore). It must be skippable and must respect reduced motion.
- **Honest labels.** Keep every simulated feature (Campus OS, eco dashboard, heat map, transit, notices, indoor) behind a "Labs" switch for V1, so that nothing simulated can be mistaken for live campus data.

1C · Critical routing (weeks 2–6)

- Merge the two A* implementations onto the worker engine, with a shared graph module and a synchronous fallback.
- "Directions" from **My location**, **Main Gate** or **any building** to any building or room code, with walk time (the existing estimate), distance and a step list built from landmarks.
- An **accessible routing profile**: the "Wheelchair Routes" switch must change the route as well as the tint.
- Shareable route links (`?route=from,to`), validated like `ping`.
- Arrival detection and re-routing when off-route by more than 25 m, GPS permitting.

1D · Seamless mobile UX (weeks 3–7)

- Thumb-zone layout: primary actions in the bottom 40% of the screen, 44×44 px minimum targets, safe-area insets (already using `viewport-fit=cover`).
- Allow pinch-zoom of the UI (remove `maximum-scale=1, user-scalable=no`) and let the canvas consume pinch gestures itself.
- **Automatic Eco mode** on the low tier, or after 2 consecutive governor down-steps, with a visible "Battery saver" chip.
- In-app browsers: test WhatsApp, Instagram and Telegram webviews, where most shared links will open, and provide an "Open in browser" fallback.
- PWA: manifest, icons, offline shell and Add-to-Home-Screen for freshers' week.

1E · Quality gates (weeks 6–8)

Device-lab sign-off against §2.6, WCAG 2.2 AA audit, DPDP privacy notice, content QA of all 257 room entries, load test of the CDN, and the §6 checklist signed by engineering, security and the university's web office.

5.2 Phase 2: The Smart Campus (months 3–9)

Table 5-1 · Smart-campus capabilities: data sources, privacy model and the existing module to graduate

Capability	Data source and pipeline	Privacy and integrity model	Existing module to wire up
Live crowd heat maps	Wi-Fi controller association counts per access point (Aruba/Cisco/Ruckus northbound APIs), aggregated per building every 5 min; optional people counters at canteens and the library.	Building-level aggregates only, k ≥ 10, no MAC addresses leave the controller, 24 h retention of aggregates.	EN:2 "Hostel & Mess Heatmap" and MT:1 occupancy heat (both simulated today).
Smart parking	Per-bay magnetometer/ultrasonic sensors over LoRaWAN, or camera edge counters with on-device inference that store no plates.	Counts only; signed occupancy per zone; stale data marked after 5 min.	c23 Campus OS parking bays (simulated); POI parking layer.
Live weather sync	On-campus weather station (rain gauge, wind, temperature) with Open-Meteo/IMD API fallback; solar position computed for 10.73°N, 79.02°E.	Public data; cache 10 min.	c17 weather (off/motes/rain), day/night lighting (`debugTime` / `hour` logic).
Events and notices	CMS with approval workflow; signed safety notices.	Publisher identity shown on every notice.	EN:2 notice boards (demo feed); NG:5 event holograms (Kuruksastra, Daksh).
Transit twin	GPS trackers on campus shuttles (MQTT, 5 s cadence).	Vehicle positions only; no driver data.	EN:2 transit (simulated loop).
Energy and sustainability	Smart-meter and solar-inverter APIs, aggregated per building.	Facilities data; daily totals public, live values internal.	EN:2 Eco-Dashboard (simulated).
Security operations console	Authenticated console (SSO + MFA) to issue closures, evacuations and drills.	Ed25519-signed broadcasts, dual approval for evacuation, full audit log.	EV:1 evacuation and MT:1 closures (replaces `?evac=`).

> **GOVERNANCE BEFORE TELEMETRY**
>
> Publish a one-page "What the campus map knows" data charter before any live feed is connected. It should cover sources, aggregation level, retention, who can issue alerts, and how to report errors. Students will trust live crowd maps only if they can see that the map cannot track individuals.

5.3 Phase 3: Next-Gen experiences (months 9–18)

WebXR AR portals

- **What exists:** c25 requests `immersive-ar` with `hit-test` (required) plus `dom-overlay`, `local-floor`, `anchors` and `light-estimation` (optional), and includes a tabletop mode. EN:2 probes `isSessionSupported` and degrades gracefully.
- **Platform reality:** WebXR AR works in Chrome on ARCore Android devices. iOS Safari still does not offer WebXR immersive AR, so iPhone users, a large share of parents and visitors, need a fallback: AR

Quick Look (USDZ export of the tabletop campus) or a camera-backed pseudo-AR view driven by device orientation.

- **Portals:** place a "doorway" anchored on the ground that opens into a 360° panorama or Gaussian-splat capture of a signature interior (library reading hall, auditorium, the heritage façades). Stream compressed splats (SPZ) only when the portal is approached.
- **Outdoor AR wayfinding** needs better positioning than phone GPS and compass (5–15 m error). Phone GPS is enough for a map dot but not for arrows overlaid on the real world. That use case needs a visual positioning system such as ARCore Geospatial in a native wrapper, so treat it as a separate, later decision.

Cinematic drone tours

- **What exists:** the NG:7 Grand Tour already bakes centripetal Catmull-Rom position and look-at splines, validates the baked spline against the analytic curve, and manages lead-in, arrival and rejoin states.
- **Next:** a keyframe timeline editor (camera rail, focal length, dwell, narration cue); bilingual narration (recorded voice preferred over TTS for the brand); music bed with ducking; chapter markers per school.
- **Real-world fidelity:** drone photogrammetry of hero buildings converted to Gaussian splats or 3D Tiles and blended with the procedural campus by level of detail.
- **Distribution:** render to MP4 in the browser with WebCodecs for Instagram and YouTube admissions campaigns; scheduled "live tour" sessions for admissions webinars.

Platform evolution

- **WebGPU** through the upgraded three.js `WebGPURenderer`: compute-shader crowds and traffic, GPU-driven culling, and a higher ceiling on desktop, with WebGL 2 fallback kept.
- **AI concierge.** The c24 palette already defines a JSON-Schema "spatial intent" (*"LLM-ready: natural language → structured spatial intent"*). Connect it to a server-side LLM with function calling restricted to that schema (navigate, show, filter, explain), with rate limiting and no free-form actions. Support English and Tamil queries, including voice.
- **Facilities twin.** BIM/IFC import for maintained buildings, and maintenance tickets pinned on the map for the Estate Office.

SECTION 6

The "Perfect Launch" Pre-Flight Checklist

Every item has an owner and a gate level. ▲ BLOCKER items stop the launch. ◆ REQUIRED items must be done or formally risk-accepted by the project sponsor. ● RECOMMENDED items may follow in V1.1. The checklist assumes delivery from a CDN-fronted static host (Vercel, Cloudflare Pages or an Nginx origin behind Cloudflare).

6.1 Build and bundle

#	Item	Gate	Owner
B-1	Commit authoring sources, `*.build.cjs` scripts and a reproducible build command to Git. The deployed artifact must be rebuildable from a tagged commit.	▲ BLOCKER	Engineering
B-2	Produce a **viewer build profile**: WorldEditor (c03, 181 KB br), debug HUDs, dev URL parameters and mutating globals compiled out.	◆ REQUIRED	Engineering
B-3	Exact-host domain lock list; production URL smoke test in CI.	▲ BLOCKER	Engineering
B-4	Embed the build stamp (`Bmuds6ios-9kbp` style) and Git SHA in a `<meta name="build">` tag and in error reports.	◆ REQUIRED	Engineering
B-5	Bundle-size budget in CI: critical path ≤ 450 KB br (V1), ≤ 350 KB br (V1.1 after splitting).	● RECOMMENDED	Engineering
B-6	Source maps uploaded to the error tracker, **not** publicly served.	◆ REQUIRED	Engineering

6.2 CDN caching and compression

Table 6-1 · Caching matrix

Resource	`Cache-Control`	Notes
HTML entry (`/` , `index.html`)	`no-cache` (revalidate with ETag)	Always fresh; tiny once JS is externalised.
Hashed JS/CSS/WASM (`app.3f9c.js`)	`public, max-age=31536000, immutable`	Filename hash changes on content change.
Data manifest (`/v1/manifest`)	`no-cache` or `max-age=60, stale-while-revalidate=600`	Points to hashed dataset URLs.
Hashed datasets, KTX2, GLB, fonts	`public, max-age=31536000, immutable`	Serve fonts with `crossorigin` and CORP.
Service-worker script	`no-cache`	Required so updates propagate.
Live endpoints	`no-store`	Telemetry is never cached.

- [ ] **Brotli-11 pre-compressed** (`.br`) for all text assets, with gzip-9 fallback; the CDN serves pre-compressed files instead of compressing on the fly. REQUIRED
- [ ] **Retire the custom 7-bit/deflate packing.** Measured on this build: the packed HTML is **944 KB** with Brotli, while the identical JavaScript served as plain Brotli is **637 KB**, a 33% saving before any code splitting. Packed inline code also misses HTTP caching across releases and V8's compiled-code cache, and costs about 28 ms of unpack and inflate even on a desktop CPU (≈ 100–150 ms on low-end phones). REQUIRED

- [ ] HTTP/2 or HTTP/3 enabled; `<link rel="modulepreload">` for the core chunk; `preconnect` only to origins actually used. RECOMMENDED
- [ ] CDN purge-on-deploy limited to the HTML and manifest; hashed assets are never purged. REQUIRED
- [ ] Origin shielding, plus a cache hit-ratio target of 95% or more during admission and convocation peaks; load-test at 10× expected peak. REQUIRED

6.3 Asset optimisation

Asset class	Today	Launch standard
3D geometry	Procedurally generated at runtime: 3,191 geometries, 3.83 M unique vertices; WorldEditor placements; ddPool de-duplication after load.	Bake static campus geometry at build time into glTF 2.0 with **Meshopt** (fast decode, good for many small meshes) or **Draco** (best for large dense meshes), merged per material per spatial cell. Quantise positions (`KHR_mesh_quantization`). Use the GPU-instancing extension (`EXT_mesh_gpu_instancing`) for trees, lamps, benches and vehicles. The procedural generator becomes a build tool.
Textures	Mostly canvas-generated (CanvasTexture × 27 sites), cached in IndexedDB (`sastra-texcache` , 192 MB budget); 269 textures on desktop, 93 on the low tier (capped to 512 px).	**KTX2 + Basis Universal** (UASTC for normal and detail maps, ETC1S for albedo) so textures stay compressed on the GPU, typically a 4–8× VRAM reduction over RGBA8. Use WebP/AVIF for UI images and card photos. Pack façade tiles into atlases or `DataArrayTexture` s keyed by material.
Shadow maps	Directional 4096² (desktop) / 2048² / 512–1024² (low tier) plus 3 spot shadows (1024²).	Bake static shadows and ambient occlusion into lightmaps or vertex colours for buildings. Keep a single dynamic shadow for moving actors only, at 1024² (mobile) / 2048² (desktop).
Audio	Procedural wind, hum and rain buffers; optional `audio/*.mp3` upgrades (not deployed).	Opus in WebM/Ogg (with AAC fallback for Safari), ≤ 48 kbps ambience loops, lazy-loaded only after the user enables audio.
Fonts	Google Fonts: Inter, Noto Sans Tamil, Cinzel and Oswald, 17 weights.	Self-hosted WOFF2 subsets (Latin + Tamil), at most 2 families and variable weights, `font-display: swap` , preload of the critical face only.
Procedural and shader caches (“gizmo caching”)	IndexedDB texture cache; `KHR_parallel_shader_compile` ; warm-up render; pre-allocated light rig (`CAMPUS_RIG_FORECAST`) to avoid program recompiles.	Keep all four. Add a geometry cache keyed by build stamp, a versioned cache-eviction policy, a quota check via `navigator.storage.estimate()` , and `navigator.storage.persist()` only after the PWA install. Cap texture-cache writes on low-storage devices.

6.4 Security and privacy configuration

- [ ] Header set from Table 3-4 deployed; CSP report-only for 7 days with zero unexplained violations, then enforced. BLOCKER
- [ ] SEC-01, SEC-02, SEC-05 and SEC-07 verified closed by re-test; findings register updated. BLOCKER
- [ ] Security View content reviewed with Campus Security (SEC-08). REQUIRED
- [ ] Privacy notice (DPDP Act 2023): location stays on the device; voice is processed by the browser vendor’s recogniser when enabled; no cookies; no tracking; preferences stored locally. Linked from the settings menu. REQUIRED

- [ ] Dependency inventory (SBOM) with versions: three.js, fflate, fonts. Licence notices included (three.js and fflate are MIT). REQUIRED
- [ ] External penetration test of the deployed origin and headers; DAST scan against the URL-parameter surface (Appendix A). RECOMMENDED

6.5 Fallback states for unsupported or degraded environments

Condition	Current behaviour	Required behaviour
JavaScript disabled	A splash spinner that never completes; no `<noscript>`.	`<noscript>` with a static campus map image, building list and contact links.
No WebGL / WebGL 2	The global error handler sets the boot title to “Failed to load” plus an error string.	Detect before boot; offer a 2D map mode (pre-rendered tiles or SVG) with the same search and directions.
Context lost	Recovery dialog with Reload (good).	Keep; add automatic restore when `webglcontextrestored` fires, and report it to RUM.
Low memory / old GPU	Device-tier heuristics (`deviceMemory` , cores, UA).	Add a frame-time probe at boot; auto-Eco; “Lite” mode (no post-processing, no shadows, DPR 1).
Reduced motion	49 branches honour `prefers-reduced-motion` (good).	Extend to camera fly-throughs (cut instead of fly) and to the tour.
Offline / flaky network	Single file works once loaded; external fonts fail open.	Service-worker app shell plus cached datasets; “offline” chip.
In-app browsers	Untested.	Smoke test in WhatsApp, Instagram and Telegram on Android and iOS; “Open in browser” prompt when WebGL 2 is unavailable.
Insecure context (http)	GPS and voice silently unavailable.	HTTPS everywhere (HSTS); explanatory message when an API is missing.

6.6 Accessibility, SEO and sharing

- [ ] WCAG 2.2 AA audit: keyboard path to every feature, focus visible, 4.5:1 text contrast in all themes, pinch-zoom allowed, no paste or selection blocking, screen-reader labels for canvas alternatives (the building list). REQUIRED
- [ ] `<html lang="en">` (missing today) and `lang="ta"` on Tamil fragments. REQUIRED
- [ ] Meta description, canonical URL, Open Graph and Twitter card with a branded campus render (1200×630), favicon and app icons, `theme-color` . None are present today. REQUIRED
- [ ] Structured data: `CollegeOrUniversity` with `hasMap` , plus `Place` entries for major buildings; `sitemap.xml` with deep links per building. RECOMMENDED

6.7 Observability and launch runbook

OBSERVABILITY

- Error tracking with source maps and build stamp; replace empty catches on critical paths with `report()` .

RUNBOOK

- **T-14 days:** feature freeze; CSP report-only; device-lab run.
- **T-7:** content freeze; accessibility and security re-test; load test.

- Privacy-safe RUM: device tier, governor rung, FPS histogram (the build already computes one), long tasks, context losses, time to first frame, time to interactive.
- Uptime and synthetic checks (load, first frame, search “TDC”, route Main Gate → Library) every 5 min from Indian PoPs.
- CSP and COEP report endpoint dashboard.

- **T-1:** production deploy behind an unlisted URL; smoke tests; on-call roster.
- **T-0:** DNS or link switch; monitor dashboards for 4 h.
- **T+1:** review errors and RUM; hot-fix window.
- **Rollback:** previous immutable build kept warm; one-command revert of the HTML pointer (target ≤ 5 min).

6.8 Sign-off

Role	Name	Signature	Date
Project lead / author			
University web office			
IT security			
Campus security (SEC-01, SEC-08)			
Sponsor (management)			

APPENDICES

Reference Inventories & Method

A URL parameter inventory (69 parameters)

"Risk" is the effect a third party can cause by sharing a link. Recommended production disposition: **Keep** (validated share parameter), **Dev** (honour only on localhost or with a signed debug token), **Remove**.

Parameter	Module	Effect	Risk	Disposition
`evac=1`	EV:1	Shows "EVACUATION ROUTE ACTIVE" banner and route	▲ CRITICAL	Remove
`geo=lat,lon | off`	c14	Overrides the GPS→map projection origin; `off` disables auto-locate	◆ HIGH	Dev
`iot=0|1|on|off|wss://…`	MT:1	Toggles the live twin; endpoint override (same host, localhost, `*.local`)	◆ HIGH	Dev
`sec=1`	c11	Opens the Security View (guard posts)	● MEDIUM	Remove
`admin=1`	c11	Admin performance HUD incl. unmasked GPU string	● MEDIUM	Dev
`fps=N`	c02, MT:3	Active frame cap (0 = uncapped)	● MEDIUM	Dev
`rest=N` · `active=N`	c02	Loop-parking thresholds (0 disables parking)	● MEDIUM	Dev
`dpr=X`	c02	Forces the pixel ratio	● MEDIUM	Dev
`msaa=0|1|2-8`	c02	MSAA sample count	● MEDIUM	Dev
`gfx=low|high`	c02	Forces the device tier	● MEDIUM	Keep (low only)
`lock=0`	shell	Disables the quality lock (enables the governor)	▽ LOW	Invert default
`logz=0` · `tg=0`	c02	Log-depth off · tier governor off	▽ LOW	Dev
`shadows=live` · `walkshadow=live`	c02	Continuous shadow refresh	● MEDIUM	Dev
`texcache=0|clear`	shell	Disables or clears the IndexedDB texture cache	▽ LOW	Dev
`pool=0` · `dd=0`	c02	Geometry pooling off · screen-size culling off	● MEDIUM	Dev
`lod` · `lodlite=0` · `lodreach=N` · `hz`	MT:3	Level-of-detail controls and reach	● MEDIUM	Dev
`hycell=N` · `hyflora=0`	c02	Vegetation cell size and flora	● MEDIUM	Dev
`aaa=0` · `forestcull=0` · `cao=0`	c02	Rendering feature toggles	▽ LOW	Dev
`fat` · `fastnoise` · `fog` · `sun` · `clock` · `tip` · `poipick` · `haptic` · `oled` · `bgtrees` · `ab` (=0)	c02, shell	Visual and interaction toggles	▽ LOW	Dev
`reveal=N` · `intro=0` · `people=1`	c02	Intro and reveal timing; crowd toggle	▽ LOW	Keep (`intro`)
`occl=0`	MT:2	Acoustic occlusion off	▽ LOW	Dev

Parameter	Module	Effect	Risk	Disposition
`sab=0` · `mtw=inline|file` · `pf=0`	MT:1	Worker transport and pathfinding toggles	▽ LOW	Dev
`hour=H`	c02	Forces time of day	▽ LOW	Dev
`weather=off|motes|rain`	c17	Forces weather	▽ LOW	Dev
`pins=a,b` · `route=0|1`	c21, c16	Preselects POI categories · route layer	▽ LOW	Keep (validated)
`ping=x,y,z`	NG:3	Meet-me pin, regex- and bounds-checked	✔ SAFE	Keep
`os` · `pal` · `tdc` · `ar` · `post` · `gov`	c23–c25, c22, EN:2	Opens Campus OS (simulated), palette, indoor demo, AR, post and governor modes	▽ LOW	Dev
`access=1` · `hc=1`	c12	Opens accessibility options · high-contrast mode	✔ USEFUL	Keep
`glow` · `dof` · `radar`	c15, c18, c19	Feature toggles	▽ LOW	Dev
`voice=0` · `audio=0` · `menu=0` · `ng=0` · `link=0` · `poi=0` · `l9=0`	various	Kill-switches (disable features or the settings menu)	▽ LOW	Dev

B Module inventory

Module	Responsibility	Raw bytes	Brotli
`c00`	three.js r128 (vendor, MIT)	613,164	122,944
`c01`	Loading-progress UI; hooks THREE.DefaultLoadingManager	4,849	1,854
`c02`	Engine core: renderer, scene, procedural campus, camera, render loop, governor, post-processing, audio, voice assistant, walk/drive modes	551,734	152,008
`c03`	WorldEditor: layout editing, asset placement, lights, export (inactive in viewer builds)	696,073	180,940
`c04`	Gate tags and label placer	42,911	13,614
`c05`	Hostel-complex boundary adjustments	3,839	1,624
`c06`	Building records and info cards; `campusData`; walk-time estimates	120,035	30,559
`c07`	Zone quick-fly dock (Academic, Hostels, Canteens, Sports …)	11,205	4,117
`c08`	Architecture/CAD dock	6,261	2,556
`c09`	UX polish styles	5,156	2,049
`c10`	Tooltips and day/night toggle	10,365	3,526
`c11`	Deep links and sharing, landmark POI layer, Security View, admin HUD	32,547	10,655
`c12`	Search (room codes) and accessibility options (high contrast)	39,268	12,528
`c13`	GPS/AR coordination state	1,666	702
`c14`	GPS “You are here”, calibration, locate dock	36,403	11,597
`c15`	Building glow and highlight	12,141	4,751
`c16`	Route planner (main-thread A*) and route ribbon	37,998	13,443
`c17`	Weather (motes, rain)	11,155	4,238
`c18`	Depth-of-field	6,877	2,613
`c19`	Radar minimap	23,407	8,420

Module	Responsibility	Raw bytes	Brotli
`c20`	Bounding-sphere repair	2,630	1,159
`c21`	POI pins (food, restrooms, parking) and directions bar	47,824	15,764
`c22`	Post-processing and performance-governor layer	31,079	10,781
`c23`	Campus OS dashboard (simulated feed)	49,920	16,602
`c24`	Spatial command palette; JSON-Schema “spatial intent” (LLM-ready)	63,544	21,159
`c25`	WebXR AR and tabletop mode	37,846	11,994
`c26`	Settings menu (Eco, POI, compass, audio/voice, wheelchair …); global teardown	34,379	9,995
`mapdata`	Embedded layout payload (v7)	61,432	14,431
`SH:1`	SH:1 domain lock	468	248
`s01`	Anti-copy / clipboard guard	1,513	683
`s02`	Quality-lock flag (`?lock`)	123	104
`s03`	IndexedDB texture cache	14,451	5,093
`IB:1`	IB:1 boot gate (readyState/lifecycle hold)	1,377	593
`s05`	Frame-buster, anti-devtools, context-loss dialog, OLED shift	4,181	1,537
`EV:1`	EV:1 emergency evacuation mode	7,416	3,021
`MT:1`	MT:1 digital twin: nav and IoT workers, heat map, path service	73,497	24,126
`MT:2`	MT:2 acoustics and occlusion	9,724	3,962
`MT:3`	MT:3 level of detail (SastraLOD)	12,541	4,564
`NG:0`	NG:0 NextGen kernel (ngx)	8,336	3,304
`NG:1`	NG:1 settings (audio/voice, archive)	18,547	5,891
`NG:2`	NG:2 theme engine (Neon, Blueprint, Matrix)	28,472	10,102
`NG:3`	NG:3 meet-me ping	25,500	9,183
`NG:4`	NG:4 warp flights	15,308	5,286
`NG:5`	NG:5 event holograms (Kuruksastra, Daksh)	18,782	6,658
`NG:6`	NG:6 X-ray roof slicer	30,004	10,526
`NG:7`	NG:7 Grand Tour	33,774	11,864
`NG:8`	NG:8 walk mode	24,780	9,490
`EN:1`	EN:1 floating action button	6,496	2,562
`EN:2`	EN:2 smart-campus suite	38,893	12,905
`IB:3`	IB:3 unpacker and chunk scheduler (fflate)	7,133	3,279
`style0`	Global stylesheet	47,208	9,445

C Browser storage inventory

Key / store	Purpose
`sastra.gx.*` (eco, poi, compass, lpTucked, glow, dof, radar, weather, route, pal, os, iot, ar, gov, post)	Settings-menu feature preferences
`sastra.ng.*`	NextGen kernel feature flags and options

Key / store	Purpose
`sastra.geo.cal.v1` · `sastra.geo.origin.v1` · `sastra.geo.auto.off`	GPS calibration points, origin, auto-locate opt-out
`sastra.labelBindings.v1` · `sastra.labelPlace.v1` · `…dockHidden.v1` · `sastra.labelNudge.v1`	Label placement (editor tooling)
`sastra.a11y.hc` · `sastra.va.sound` · `sastra.ctx.reload.v1`	High contrast, legacy sound preference, context-loss reload guard
WorldEditor layout keys	Editor layouts; ignored in viewer builds
`sessionStorage` (8 sites)	Once-per-session guards (e.g. GPS auto-resume)
IndexedDB `sastra-texcache` (stores `meta`, `tex`)	Encoded procedural textures; 192 MB budget; versioned by build signature

No cookies are set, and no personal data is stored. Location is held in memory only, apart from optional calibration points.

D Global API surface (measured at runtime)

Global	Capability	Production
`SastraTwin`	IoT state, `inject()` arbitrary telemetry, `enable()`, `findPath()`, `replan()`	Read-only state only
`toggleEmergencyMode`	Shows or hides the evacuation banner and route	Remove
`SastraNG` · `SastraSettingsNG`	Enable or disable any registered feature; options	Remove
`SastraTheme` · `SastraWarp` · `SastraHolo` · `SastraXRay` · `SastraGrandTour` · `SastraGTAWalk` · `SastraPing`	Drive individual NextGen features	Dev only
`SastraEnterpriseUI` · `SastraSmartCampus`	Enterprise layer state and smart-campus features	Dev only
`SastraLOD` · `SastraAcoustics`	LOD and acoustics tuning	Dev only
`debugTime`	Getter/setter forcing the time of day	Dev only

E Methodology, environment and limitations

Artifact	`SastraMap_Enterprise.html` · 1,357,907 B · SHA-256 `316760eeff331bc256865651fe235637b3f1a2b04948a3433e37c55068ac4019`
Repository context	`sakthizzportraits-spec/Sakthi-mapz` @ `6020427` contains `SastraMap_UltraPerformance.html` (2.59 MB, earlier lineage with a meta CSP). No sources, build scripts or tests.
Decoding	Reimplemented the build's IB:3 unpacker (7-bit stream, escape table `[0,13,60]`, 805,565 bytes) and raw-DEFLATE inflate. The output matched the 27 declared chunk lengths exactly (2,586,865 chars).
Static review	Prettier-formatted 47 modules (≈ 112k lines, three.js excluded). Pattern census (APIs, sinks, parsers, storage, timers). Function-level reading of the security shell, render loop, governor, IoT/nav workers, GPS, voice, evacuation, editor gating and data modules.
Runtime harness	Playwright 1.56.1 · Chromium 141.0.7390.37 headless · ANGLE/SwiftShader WebGL 2 · local HTTP origin (`localhost`, permitted by the domain lock).

Instrumentation	WebGL prototype hooks (draw/instanced draw counts, triangles by primitive mode, program/texture/buffer creation, upload bytes); a three.js renderer proxy (per-`render()` pass attribution via `renderer.info`); scene-graph census; CDP `Performance.getMetrics`, `Runtime.getHeapUsage` after forced GC, and `HeapProfiler` sampling; long-task observer; network and egress-proxy logs.
Profiles	Desktop 1440×900 at DPR 1 (high tier). Mobile: Pixel 7 emulation (412×915, DPR 2.625, touch, mobile UA) with `navigator.deviceMemory = 4` (low tier).
Limitations	Software rasterisation makes absolute timings pessimistic (load, frame time, long tasks); counts and structure are exact. No physical-device thermal measurements were taken: the §2.5 rules and §2.6 budgets are engineering targets to verify in a device lab. Mobile emulation does not reproduce mobile GPU drivers.